作品编号：CACR20260CR5XN

作品类别： ☑软件设计 ☐硬件制作 ☐工程实践

☐密码应用技术 ☐其它

2026 年第十一届全国密码技术竞赛作品设计报告

作品题目：园区边缘设备国密与后量子

混合安全通信软件设计实现（A1-31）

2026 年 10 月 19 日

中国密码学会

基本信息表

编号：CACR2026OCR5XN

作品题目：园区边缘设备国密与后量子混合安全通信软件设计实现（A1-31）

作品类别：☑软件设计　□硬件制作　□工程实践　□密码技术应用　□其它

作品内容摘要：

工业园区边缘通信需要兼顾国密算法选型、长期数据保密与存量设备渐进迁移。传统公钥机制面临未来量子密码分析的风险，而整体替换设备又受到运行连续性、接口及资源条件制约。通信保护还必须区分报文写出、对端接收与业务处理，避免仅凭发送成功判断控制操作已经完成。

针对 A1-31 赛题，本作品设计并实现 EdgeHybrid 软件原型，以 SM2 与 ML-KEM-768 混合四步握手建立双分支共享材料。采用 HMAC-SM3 实例化 HKDF，本文简称 HKDF-SM3。结合 T2/T4 分阶段转录派生确认与应用密钥，并通过 SM4-GCM 保护双向记录。可信配置允许传统模式与混合模式共存，混合失败不静默回退。

作品的技术工作集中在三个层次：以 T2/T4 分阶段转录将身份、协商参数与两分支建钥材料绑定；用严格记录序号和匹配 ACK 连接通信保护与业务处理；通过运行编号、源码清单、程序身份和原始日志组织可复现实验。本机 Web 工作台将这些机制转化为设备连接、温度上报、间隔控制和证据导出操作。

在 Windows 本机 TCP 环境下，同生产源码的 QPC 测试宿主完成混合模式 1,000/1,000 次正式握手，客户端完整握手调用观察区间的平均耗时为 1.1479 ms，P95 为 1.4731 ms，长期身份初始化与 TCP 建连位于计时区间之外。已建通道的 Suite 2 控制请求—ACK RTT P95 为 0.2645 ms；4,096 B 载荷的 SM4-GCM 加密／解密吞吐约为 605.92／650.78 MB/s。握手、业务与原语分别计量，原始样本、环境和复算脚本共同构成数据依据。

本作品采用“国密身份认证＋混合建钥”的渐进迁移路径：SM2 承载身份认证，ML-KEM-768 提供后量子建钥分支。验证包括 Windows 软件原型、模拟设备，以及 Android ARM64 手机的跨设备温度上报与控制功能；本文正式性能统计仍来自 Windows 本机批次。协议组合安全分析、后量子签名认证及目标工业硬件适配是后续研究和工程验证方向。

关键词（五个）：后量子密码；国密算法；混合密钥协商；业务因果确认；可复验证据

目　录

1.作品功能与性能说明 **4**
1.1 研发问题与威胁模型 **4**
1.1.1 工业边缘迁移要解决的问题 4
1.1.2 HNDL 与 Mosca 迁移风险框架 4
1.1.3 设计约束与处理原则 4
1.1.4 威胁—机制—实现—证据映射 4
1.2 核心技术贡献与设计原则 **5**
1.2.1 混合建钥与渐进密码迁移 5
1.2.2 T2/T4 分阶段转录绑定与协商完整性 5
1.2.3 安全记录与业务因果确认 5
1.2.4 可复现实验与证据追踪 5
1.2.5 设计增量与评价依据 5
1.3 工程功能与协议对象 **6**
1.3.1 功能模块与证据入口 6
1.3.2 线格式与受保护记录 7
1.3.3 控制平面与数据平面 7
1.3.4 会话生命周期 8
1.4 赛题要求与本作品实现映射 **8**
1.5 工业场景逻辑架构 **9**
1.6 性能概况 **10**
2.设计与实现方案 **11**
2.1 实现原理 **11**
2.1.1 软件原型与部署视角 11
2.1.2 软件实现模块架构 11
2.1.3 原语参数、接口与用途 13
2.1.4 ML-KEM-768：数学结构与接口语义 13
2.1.5 SM2、SM3 与 SM4-GCM 接口集成 14
2.1.6 Suite 2 四步握手与双方材料状态 14
2.1.7 T2/T4 分阶段转录与密钥调度 15
2.1.8 双向记录保护与严格序号 17
2.1.9 面向工业控制语义的因果确认与审计证据 18
2.1.10 协议安全假设与工程边界分析 18
2.1.11 Android 实机验证终端 20
2.2 运行结果 **20**
2.2.1 工作台准入与便携运行 21
2.2.2 温度验收、控制 ACK 与报文字段 22
2.2.3 多身份管理与逐目标批量操作 23
2.2.4 链式审计摘要与证据导出 24
2.2.5 长期身份维护与完整会话更新 25
2.2.6 安全实验与版本化证据入口 26
2.2.7 分层详情与容量可视化 26
2.3 技术指标 **27**
3.系统测试与结果 **28**
3.1 测试方案 **28**
3.1.1 环境、版本与执行批次 28

3.1.2 软件输入、时钟与证据采集 29
3.1.3 计时分辨率与高精度复核 29
3.2 功能测试 29
3.2.1 基础密码原语与所选向量 30
3.2.2 会话协商、降级与身份认证 30
3.2.3 记录认证与严格序号 30
3.2.4 因果确认、元数据摘要与身份维护 31
3.2.5 异常输入、受控中断与恢复 31
3.2.6 解析器 Fuzz、语句覆盖率与并发检查 32
3.3 性能测试 33
3.3.1 控制请求—ACK RTT（E01） 34
3.3.2 密码原语适配器（E02—E05） 34
3.3.3 20 设备批量与单进程资源（E06/E07） 35
3.3.4 参考目标与评价口径 36
3.3.5 从原语成本到用户批量耗时 36
3.4 测试数据与结果 36
3.5 安全行为、定向功能与质量处置 38
3.5.1 协商篡改和记录损坏（E09/E10） 38
3.5.2 七组定向补测（G01—G07） 38
3.5.3 静态审计、外部对照与发布回归 39
3.5.4 高精度测量与代码质量保障 39
3.5.5 受控目录下的生命周期验证 41
3.6 证据导航与离线复算入口 42
3.7 手机跨设备功能验证 43
4.应用前景 44
4.1 本机业务闭环的三个实例 44
4.1.1 模拟温度上报与网关验收 44
4.1.2 设置上报间隔与设备状态 ACK 44
4.1.3 完整会话换钥与新会话业务 44
4.2 工业业务映射与适配条件 45
4.3 部署成本因素（定性） 45
5.结论 46
5.1 三项核心成果 46
5.2 已完成能力与工程应用条件 46
5.3 后续方向与结束语 47
附录 A 术语与缩略语 48
附录 B 正文引用与参考文献 50
附录 C 标准算法说明与线格式解析片段 51
C.1 SM2 签名与 SM3 压缩流程 51
C.2 完整单帧字段解析示意 52
附录 D 关键机制失效与故障注入验证 53
D.1 实验设计与判据 53
D.2 贡献对应与复现 53

1. 作品功能与性能说明

1.1 研发问题与威胁模型

1.1.1 工业边缘迁移要解决的问题

本作品面向园区边缘设备与网关之间的遥测和控制通信。设计目标是在保留国密算法选型和显式兼容策略的同时，引入后量子建钥分支，并使操作结果能够由通信与业务证据共同核对。当前软件实现对应模拟温度、采样间隔及身份维护，并以手机电池温度和手电筒补充实机验证；工业现场设备接口仍需单独适配。

- **迁移与资源**：不同设备的运行周期、接口和资源条件不同；传统身份通过可信配置保留，混合模式优先，失败不静默回退。
- **长期保密**：攻击者可保存当前握手与密文，未来再尝试解密；建钥分支与在线身份认证需要分别分析。
- **业务可信**：写入 socket 不等于操作完成。遥测由网关验收，控制由设备返回实际生效状态，再由网关核验。

1.1.2 HNDL 与 Mosca 迁移风险框架

Shor 算法揭示传统整数分解与离散对数机制在相应量子计算模型下的风险；HNDL 则关注历史密文被保存后回溯解密的情形。[1][2]

令 X 为数据仍需保密的时间，Y 为完成迁移所需时间，Z 为具备相关密码分析能力的量子计算机出现前的估计时间。Mosca 框架以 $\mathbf{X + Y > Z}$ 提示提前迁移的必要性；各量必须结合资产、工程安排与假设评估，而不是本作品给出的固定时间预测。[2]

1.1.3 设计约束与处理原则

表1.1 迁移约束与设计回应

约束	设计回应
算法与部署资源	采用标准参数与上游密码原语，单列原语、握手、业务和进程资源成本。
存量与混合身份并存	可信配置规定最低模式；混合协商字段由身份认证、阶段转录与握手确认共同保护。
发送成功与业务完成不同	维护 queued→writing→written→confirmed；确认条件按业务类型定义。
报文和运行环境差异	区分线格式固定开销、用户态握手字节与网络条件，不混合不同版本和计量层次。
可复现与边界可追踪	每类结果保留命令、版本、run_id 和原始输出，安全 / 实验 / 工程边界分别说明。

1.1.4 威胁—机制—实现—证据映射

网络敌手可监听、截断、修改和重放消息；长期威胁还包括未来对存档流量的离线分析。威胁树按保密、身份、协商、业务与证据分支展开，下面把分支直接映射到机制、源码和验证入口。

表1.2 威胁树分支与验证路线

威胁分支	机制	主要模块	证据入口
A 长期流量保密	SM2＋ML-KEM 混合建钥；HKDF-SM3	cryptosuite / handshake	参数与接口检查；历史 H；安全边界

威胁分支	机制	主要模块	证据入口
B 冒充与重放	身份签名、可信配置、严格 Seq	handshake / record / policy	TC-07—13；E09、E10
C 协商降级	签名、T2/T4 与 Finished	handshake / keyschedule.go	9 个降级变体及 E09 中继试验
D 虚假业务确认	匹配的设备状态 ACK、四态操作	app / live	E01、E06；G02—G05
E 审计误改	所选元数据的链式摘要与可信文件哈希	exports / evidence	G01；公开导出复算
F 随机数、密钥泄露与 DoS	安全随机源、密钥分层、预算和安全失败	cryptosuite / handshake / wire	生命周期与预算用例；§2.1.10

1.2 核心技术贡献与设计原则

作品围绕混合握手、业务因果确认和可复现验证三项贡献展开。协议设计解决身份、协商与建钥材料的绑定；业务层解决“已经写出”和“确已处理”的区分；验证层将每项结论关联到源码、程序和原始记录。工作台、设备池与批量操作为三者提供统一入口。

1.2.1 混合建钥与渐进密码迁移

Suite 2 采用 SM2 密钥交换与 ML-KEM-768 的共享结果，Suite 1 提供可信配置允许的传统模式。团队聚焦于四消息混合握手、模式策略、身份约束及失败状态机的设计与实现；底层原语分别调用 Go 标准库和 gmsm 的相应接口，参数及来源见表2.2和表2.7。

1.2.2 T2/T4 分阶段转录绑定与协商完整性

前两条消息形成 T2，用于展开两个方向的 Finished 密钥；四条完整消息形成 T4，用于展开应用方向密钥、Nonce 前缀和 SessionID。身份签名、SM2 确认和 Finished 共同保护协商内容，各输入均不包含自身输出。精确流程及密钥材料见 §2.1.6—2.1.7。

1.2.3 安全记录与业务因果确认

$$\text{written} \neq \text{confirmed}$$

严格 Seq 与 SM4-GCM 保证所接纳记录通过会话、方向、顺序和认证检查；四态操作进一步回答“本次业务是否得到相应确认”。遥测 confirmed 是网关验密和业务校验后的接收观测，控制 confirmed 则要求设备实际处理后返回匹配 ACK。

1.2.4 可复现实验与证据追踪

以运行编号、源码清单、构建身份、会话和操作标识串联原始日志，形成可复算的实验材料。指标主表统一摘要、结果章节和总结中的数值，保留计算公式与原始文件入口。各性能批次保持原有版本身份，界面修订与新构建另立验证记录。

1.2.5 设计增量与评价依据

设计增量体现为赛题约束下的组合协议、失败处理和业务状态机。表1.3将具体问题、实现工作和验证依据对应起来，分别评价协议机制与工程实现。

表1.3 核心贡献的工程增量与证据

贡献	具体问题	实现增量与当前证据
A 混合握手与策略绑定	国密身份、传统兼容和后量子建钥需要同时满足；异常协商不能被误作合法兼容。	将 SM2 交换、ML-KEM-768、身份签名、S1/S2、T2/T4 与 Finished 组织为四消息协议；可信配置确定最低模式。密钥调度测试核对两分支依赖，篡改与不回退测试核对失败路径。已有证据支持实现对应性，完整组合安全分析仍需补充。
B 记录保护与业务确认	写出成功无法确定控制是否生效；错误、迟到和旧会话 ACK 可能混淆操作结果。	将严格记录序号与 queued→writing→written→confirmed 关联；控制确认核对设备、SID、操作及实际生效值。G03 的截留、迟到、旧会话和错误关联用例支持具体语义；当前确认对象为软件设备状态。
C 可核对的验证与发布	多轮修改和补测容易混淆代码版本、重复结果和计量口径。	关联 run_id、源码清单、EXE 身份、原始日志与验证索引；分列历史、补测和复用。离线复算脚本及指标 / 引用索引随包提供，保留原始样本与各版本身份。

贡献评价以机制设计、赛题适配和实现验证为依据。公开 TLS 基线用于比较各实现整体成本；分支性能收益需要另作同条件消融实验。

1.3 工程功能与协议对象

1.3.1 功能模块与证据入口

表1.4 核心功能模块、实现与证据

模块	核心职责	主要实现	关键证据
F01 ML-KEM 接口	生成、封装、解封装与句柄管理	internal/cryptosuite	TC-01；E02/E03
F02 国密接口	SM2 签名 / 交换、SM3、SM4-GCM	internal/cryptosuite	TC-02—04；E04/E05
F03 混合握手	四消息协商和双向认证	internal/handshake	历史 H；TC-05/06
F04 协商完整性	阶段转录、签名与 Finished	handshake/keyschedule.go	TC-07—09；E09
F05 因果确认与摘要	操作状态、ACK 关联、链式审计摘要	internal/live；internal/exports	TC-14/15；G01/G03
F06 多身份管理	设备视图、准入、会话与身份生命周期	internal/live；cmd/fleet	20 身份联调；G06/G07
F07 批量控制	逐目标下发、终态与错误展示	internal/live；工作台前端	E06；G04
F08 本机 Web 工作台	本机服务、授权、随包前端及导出	cmd/console；internal/console	正式 EXE 业务短流程

审计追踪视图负责事件筛选、关联记录和证据导出。预编译套件可在本机直接启动，浏览器承载界面；独立命令行角色与控制台进程内的模拟设备共享协议实现。

1.3.2 线格式与受保护记录

表1.5 线格式与受保护记录字段

层次 / 字段	长度	编码	语义
第一层：**wire** 帧（所有握手与记录消息的外层）			
Length	4 Bytes	Uint32 Big-Endian	其后剩余长度（= 1 版本 + 1 类型 + 载荷长度）；不含本 4 字节自身。
Version	1 Byte	Fixed 0x01	wire 帧版本，当前为 1（wire.Version = 1）。握手消息体内部另有独立的握手版本号 2，二者不可混同。
Kind	1 Byte	Uint8 枚举	1 ClientHello、2 ServerHello、3 ClientAuth、4 ServerFinished、16 ProtectedRecord、240/241 实验室消息。
Payload	变长	消息体 / 记录	握手消息体或一条受保护记录；帧上限 HardMaxFrame = 64 KiB。
第二层：受保护记录头（仅 **ProtectedRecord**，固定 **33** 字节）			
RecVersion	1 Byte	Fixed 0x01	记录格式版本。
Suite	2 Bytes	Uint16 Big-Endian	套件号：1 传统国密、2 混合（与 policy.Suite 一致；**本实现没有 Suite 0**）。
RecKind	1 Byte	Uint8	1 Telemetry、2 Control、3 Ack。
Direction	1 Byte	Uint8	1 设备→网关、2 网关→设备；用于方向绑定与校验。
SessionID	16 Bytes	KDF 派生	会话标识，绑定进每条记录头并作为 AEAD 的 AAD 参与认证。
Epoch	4 Bytes	Uint32 Big-Endian	换钥纪元序号；位于记录头，不占用 96 位 Nonce。
Seq	8 Bytes	Uint64 Big-Endian	方向内单调序列号；与 4 字节方向前缀拼接构成 96 位 Nonce，接收端以 seq == next 严格校验。
Ciphertext	变长	SM4-GCM	载荷密文，长度上限 MaxPlaintext = 16 KiB。
Tag	16 Bytes	GCM 认证标签	覆盖记录头（AAD）与密文。
开销口径：一条受保护记录的固定开销 = 2（wire 版本+类型）+ 33（记录头）+ 16（标签）= 51 字节，不含外层 4 字节长度前缀（record.FrameOverhead = 51）。Nonce = 4 字节方向前缀 // 8 字节 Seq（共 12 字节 / 96 位）。			

外层 Length 为其后字节数，不含 4 B 长度自身。受保护记录固定开销为 **2 + 33 + 16 = 51 B**，其中 2 B 为 wire 版本 / 类型；若计入长度字段，总线格式开销为 55 B。握手消息体版本与外层 wire 版本不同。

1.3.3 控制平面与数据平面

在系统运行架构中，EdgeHybrid 严格执行控制平面（Control Plane）与数据平面（Data Plane）解耦：控制平面负责非对称协商、公钥身份交换及纪元换钥控制，数据平面负责轻量 SM4-GCM 载荷与单调 Nonce 快速转发。

1.3.4 会话生命周期

会话生命周期依次包括初始化、协商、接纳、更新与结束。长期身份世代与临时会话纪元分别管理；重连和换钥在关闭旧 Channel 后执行完整新握手。表1.6使用便于阅读的阶段名称概括对应行为。

表1.6 会话状态、触发条件与当前行为

当前状态	事件或条件	后续状态	当前行为与范围
S_INIT	客户端按可信配置发起连接	S_HELLO_SENT	生成 32 B 握手随机数及所需临时密钥；混合模式携带 ML-KEM 公钥。
S_HELLO_SENT	收到并检查 ServerHello	S_SUITE2_NEGOTIATING	核对身份、协商字段、SM2 确认与签名；具体检查顺序以握手实现为准。
S_HELLO_SENT	超时或输入不合法	结束当前尝试	按配置预算返回错误并关闭；重新连接执行新握手，不恢复旧密钥。
S_SUITE2_NEGOTIATING	四消息与对端确认完成	S_ESTABLISHED	按 T4 派生两把各 16 B 应用密钥、两个 4 B 前缀和 16 B SID；序号从 0 开始。
协商进行中	结构、身份或确认检查失败	S_TERMINATED	拒绝当前尝试，不返回可用 Channel，不放行业务。
S_ESTABLISHED	配置阈值或明确换钥操作	S_REKEYING	关闭旧 Channel，执行完整新握手；不保证零中断。
S_REKEYING	新握手成功并接纳	S_ESTABLISHED	在新 SID 上继续业务；G3 验证范围见§3.6。

1.4 赛题要求与本作品实现映射

表1.7按原题第 1—6 项对应实现、验证依据与应用条件，供读者从赛题要求定位设计和测试。

表1.7 原题第 1—6 项要求、实现、证据与边界

原题要求	本原型实现	证据	边界
1 密钥生命周期 生成/配置/使用/轮换/吊销/销毁；区分长期身份与临时会话密钥；敏感密钥不入日志	区分设备/网关长期身份密钥与临时会话材料；提供身份维护、会话管理与完整换钥（非带内更新）	源码中的身份与会话管理实现；既有生命周期联调日志与对应定向测试	软件清理不作物理介质擦除保证；保持“日志不含敏感密钥”的约束，不宣称已覆盖所有库内副本
2 双向认证与混合密钥建立 会话密钥同时依赖 SM2 协商与后量子封装；SM3 派生绑定身份/随机数/算法标识/握手摘要；不得简单截断或异或	SM2 身份认证与 SM2 密钥交换协议+ ML-KEM-768；HKDF-SM3 带域分隔绑定 ID、随机数、协商参数与阶段转录（T2/T4）	协议实现；握手与篡改测试；四项外部独立 SM2 对照日志（Bouncy Castle + OpenSSL）	外部对照只验证所选 SM2 行为；不等于整套协议取得独立证明，也不等于已获得后量子身份认证

原题要求	本原型实现	证据	边界
3 SM4 认证加密与防重放 保护遥测与控制指令；同密钥下随机数/计数器不重复；支持定期换钥与安全重连	SM4-GCM 记录保护；Nonce = 4B 方向前缀 ‖ 8B 序号；严格 seq == next，AEAD 成功后推进接收状态；重连/换钥均执行完整新握手	记录层源码；场景日志；联调中的遥测接收观测与控制 ACK	本版本不提供会话恢复；须区分“安全重连”与“恢复旧会话”
4 传统/混合共存与防降级 默认优先混合；删除或篡改协商字段必须导致握手失败；说明兼容边界、迁移步骤与防降级机制	可信配置控制 Suite 1 / Suite 2，混合优先；最低模式升级后关闭不再符合策略的旧会话。所测篡改在结构、身份或握手确认阶段拒绝。	模式协商与篡改测试；策略升级回归及其定向 race 补测	显式允许传统身份不等于允许攻击者强制静默回退；降级拦截由软件测试覆盖，非形式化证明
5 20 台模拟设备联调与指标统计 握手时延/报文长度/峰值内存/CPU 时间/吞吐率/连续 1000 次成功率；提供可复现脚本与原始结果	1 台网关 + 20 个模拟身份的共存与业务闭环；历史冻结批次 T/H/P 各 1,000 次连续握手及批次资源记录	experiments/directed_verification/lifecycle_20devices.log；历史 T/H/P 汇总与原始索引；tools/verify_handshake_samples.py	三组握手各 1,000 条可离线复算；CPU/峰值内存为进程批次口径，非逐次握手值；20 身份联调不代替同步并发性能实验
6 威胁分析与完整交付 分析 HNDL/中间人/重放/降级/随机数失效/长期密钥泄露/DoS；提交源码、构建说明、协议流程、密钥状态、测试报告、第三方组件与许可证	给出威胁模型与有界安全声明；交付源码、构建说明、协议/状态定义、测试材料与第三方组件版本/许可证	source/、runtime/build_info.json、report/、experiments/、tools/、licenses/	指定测试通过和归档完整，不等于全场景无缺陷、形式化证明或第三方测评认证

1.5 工业场景逻辑架构

图1.1从业务视角展示模拟业务、代理、密码、调度与工作台，图2.2进一步给出源码模块的实现分层。

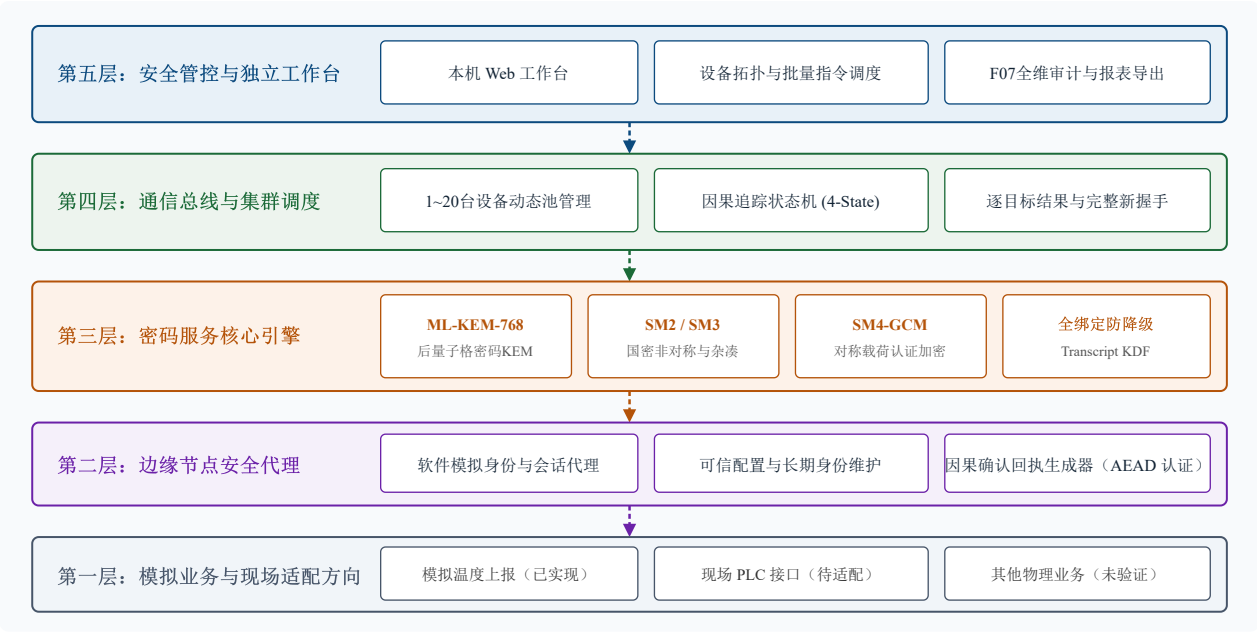


图1.1 工业场景逻辑架构

沿数据路径，控制面先完成身份认证与建钥，数据面再保护遥测及控制记录，管理面按业务类型记录确认并导出证据。现场 PLC 等目标接口标为适配方向，与当前模拟业务区分。

1.6 性能概况

在Windows本机TCP环境下，混合模式完整握手平均耗时1.1479 ms，P95为1.4731 ms，正式尝试成功1,000/1,000次；已建通道控制请求—ACK RTT的P95为0.2645 ms。4,096 B载荷下SM4-GCM加密／解密吞吐约为605.92／650.78 MB/s。系统完成20个模拟身份的业务联调；各指标的计时区间、环境和批次在第3章分列。

2. 设计与实现方案

2.1 实现原理

2.1.1 软件原型与部署视角

当前原型由本机工作台、网关角色、模拟设备、可选 Android 实机终端和证据导出组成。软件端点通过真实 TCP 通道执行握手与记录收发；图2.1的实线表示当前实现，灰色虚线表示现场设备适配方向。

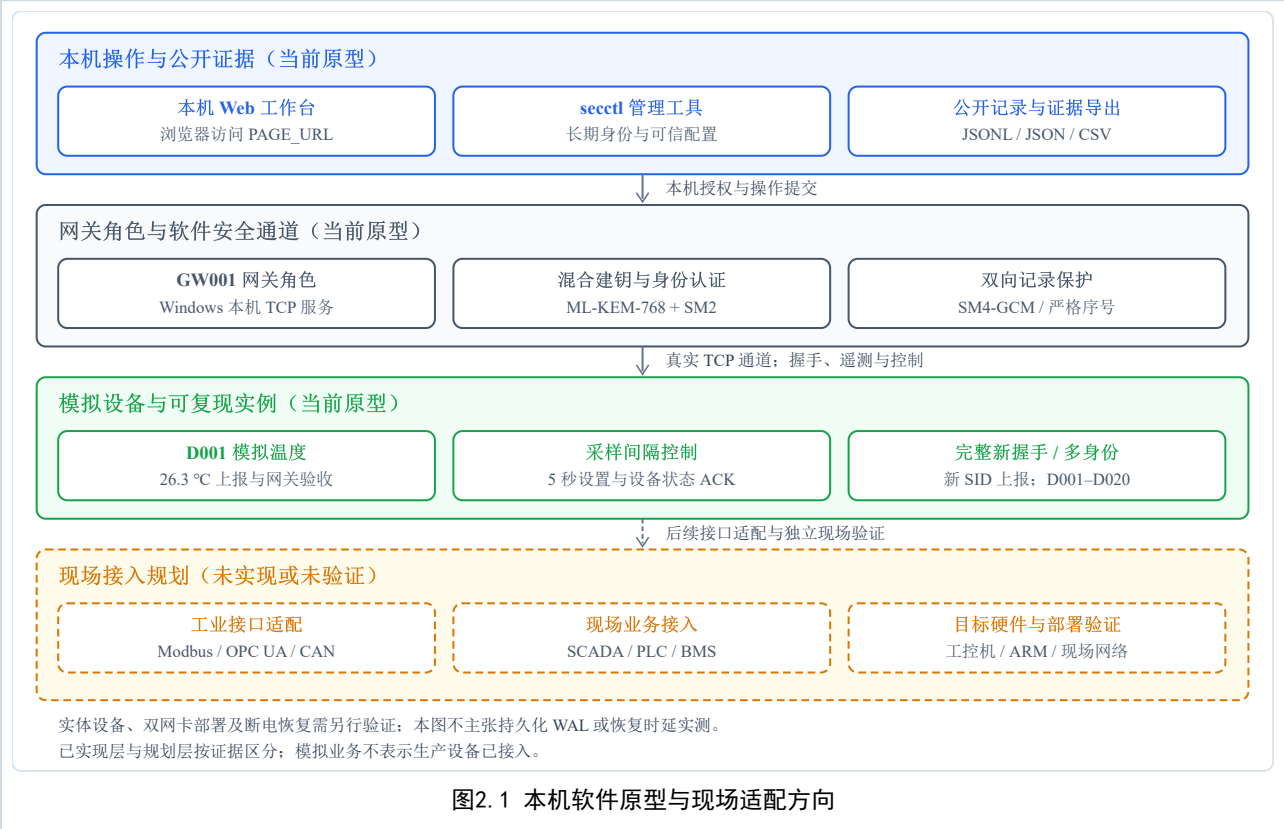


图2.1 本机软件原型与现场适配方向

目标部署适配：当前完成本机软件、模拟设备及 Android ARM64 手机功能验证；后续结合 Modbus / OPC UA 接口、工业 ARM / MCU 平台和实体环境开展适配。部署条件集中见 §5.2。

2.1.2 软件实现模块架构

软件按表示与操作、API 守卫、协议与记录、设备与会话、事件与导出组织职责。模块接口使管理请求、密码状态与业务结果分别处理，架构关系见图2.2。

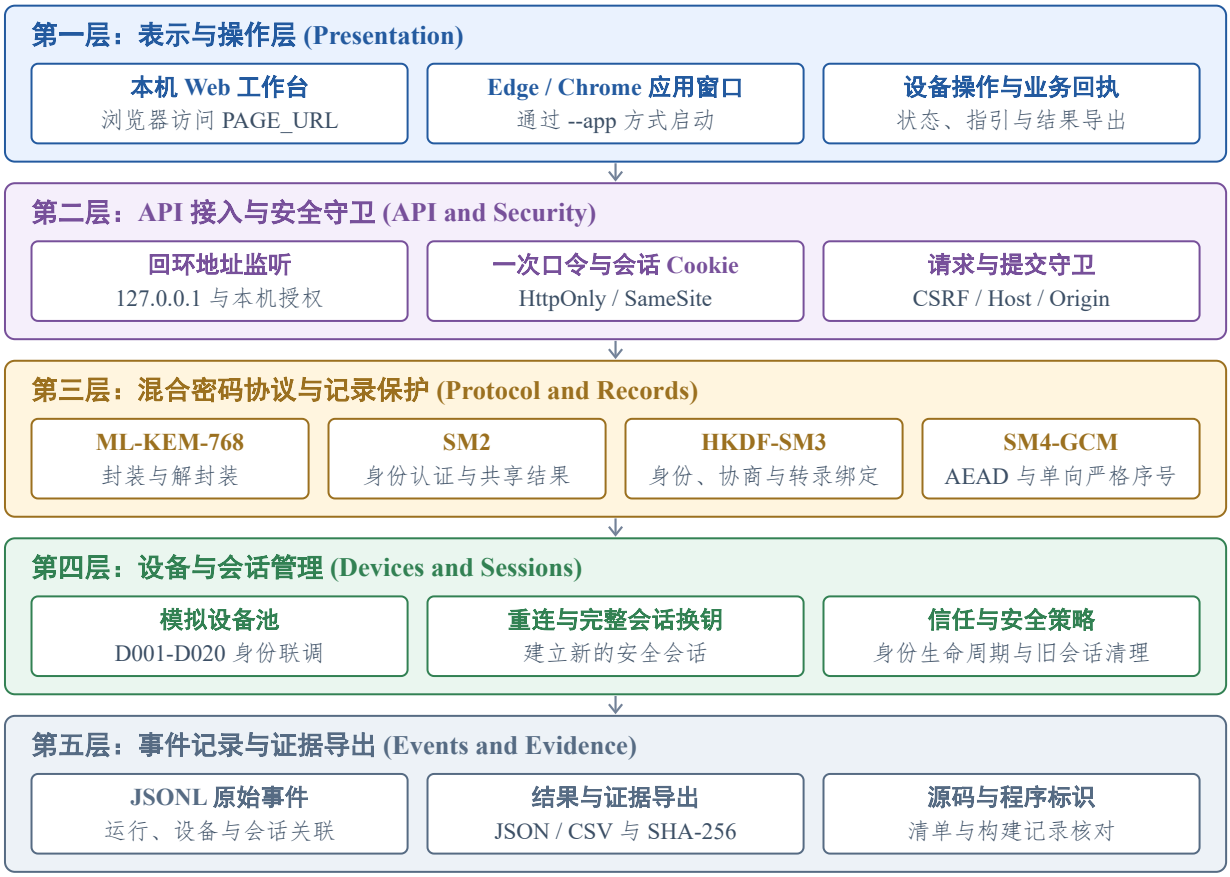


图2. 2 软件实现模块架构

表2. 1 交付工具、职责与运行条件

职责	实际交付工具	功能	边界
本机工作台	EdgeHybridInteractive.exe	提供本机HTTP服务、随包前端、设备操作、日志和导出。	需本机浏览器；图形入口不依赖开发工具链。
网关与设备	gateway.exe device.exe	执行可信配置约束的握手、SM4-GCM记录保护及设备业务。	工业接口和实体硬件适配另行验证。
多身份联调	fleet.exe	以并发软件任务运行多个模拟身份的共存、业务与生命周期检查。	输出的总墙钟时长标明非性能基准；没有同步起跑分位数。
身份维护	secctl.exe	提供状态检查、初始化、身份与密钥生命周期操作。	以实际命令帮助和交付指南为准。
基准入口	bench.exe pbench.exe	执行本实现传统/混合模式和公开混合基线的限定实验。	保持各自配置、版本、原始样本与计量口径。
测试场景	scenario.exe	测试专用执行文件，身份由构建记录中的 test_only 标识。	不作为业务服务或原语性能基准。

2.1.3 原语参数、接口与用途

参数规格、序列化尺寸与安全属性分开描述。ML-KEM-768 采用 FIPS 203 参数，国密原语按相应标准及实际接口调用；团队负责协议组合与工程集成。[3][4][5][6][7]

表2.2 密码原语参数规格与用途

原语	规范依据	结构 / 参数	关键尺寸	安全范围	当前用途
ML-KEM-768	FIPS 203	Module-LWE；k=3，n=256，q=3329	公钥 1,184 B；密文 1,088 B；共享秘密 32 B	标准安全类别 3；依赖相关假设	混合建钥后量子分支
SM2	GB/T 32918 系列	256 位素数域椭圆曲线	非压缩公钥 65 B；私钥标量 32 B	经典公钥机制；不提供后量子身份认证	身份签名与密钥交换
SM3	GB/T 32905	64 轮压缩	摘要 32 B；分组 64 B	抗碰撞、HMAC 与 KDF 性质分别要求，不把摘要长度当统一安全强度	阶段转录、HMAC 与 HKDF
SM4-GCM	GB/T 32907；GCM；所测向量见 RFC 8998	SM4 分组密码与 GCM 认证加密	密钥 16 B；标签 16 B；Nonce 12 B	要求同密钥 Nonce 不重复；安全范围依使用条件	双向载荷保护

2.1.4 ML-KEM-768：数学结构与接口语义

参数为 n = 256、q = 3329、k = 3，取 $R_q = \mathbb{Z}_q[X]/(X^{256} + 1)$。公开矩阵 A 与短向量 s、误差 e 形成 t = As + e（mod q）；相应模格问题与 KEM 变换为标准机制提供安全依据。这里说明正确集成所需结构，完整算法以 FIPS 203 为准。[3][8][9]

因为 q−1 = 13×256，模 q 下可取 256 次单位根，而不存在 512 次本原单位根。ML-KEM 的 NTT 对应 128 个二次因子，将多项式乘法转换为 NTT 域运算；它属于上游标准库实现，不是团队新增算法。本节的数学结构说明不作为独立性能成果。[3]

算法1　ML-KEM-768 密钥生成与封装（标准流程说明）

```
Algorithm ML-KEM-768.KeyGen()  // k = 3, eta1 = 2
 1: d <- RandomBytes(32); z <- RandomBytes(32)
 2: (rho, sigma) <- G(d || byte(3))
 3: for i,j = 0,1,2: A_hat[i][j] <- SampleNTT(rho || byte(j) || byte(i))
 4: for i = 0,1,2: s[i] <- SamplePolyCBD_eta1(PRF_eta1(sigma, byte(i)))
 5: for i = 0,1,2: e[i] <- SamplePolyCBD_eta1(PRF_eta1(sigma, byte(i+3)))
 6: s_hat <- NTT(s); e_hat <- NTT(e)
 7: t_hat <- A_hat * s_hat + e_hat
 8: ek <- ByteEncode_12(t_hat) || rho                // 1184 B
 9: dk <- ByteEncode_12(s_hat) || ek || H(ek) || z    // 2400 B
10: return (ek, dk)

Algorithm ML-KEM-768.Encaps(ek)
 1: m <- RandomBytes(32); (K, r) <- G(m || H(ek))
 2: c <- K-PKE.Encrypt(ek, m, r)                     // 1088 B
 3: return (c, K)                                    // K: 32 B
```

算法2　ML-KEM-768 解封装与隐式拒绝（标准流程说明）

```
Algorithm ML-KEM-768.Decaps(dk, c)  // internal outline
 1: parse dk as encoded_s_hat || ek || h || z
 2: m_prime <- K-PKE.Decrypt(encoded_s_hat, c)
 3: (K_prime, r_prime) <- G(m_prime || h)
 4: c_prime <- K-PKE.Encrypt(ek, m_prime, r_prime)
 5: K_reject <- J(z || c)
 6: K_out <- constant_time_select(c == c_prime, K_prime, K_reject)
 7: return K_out
```

byte(i) 是单字节计数器，s 与 e 分别使用 0—2、3—5。等长非法密文通过 J(z ∥ c) 使用完整密文派生替代秘密；结构长度和输入合法性检查由对外接口另行处理。2,400 B 为标准扩展私钥编码长度，不是本项目尺寸测试序列化后的测量值。实际 ML-KEM-768 来自 Go crypto/mlkem，集成边界见 §2.1.10。

2.1.5 SM2、SM3 与 SM4-GCM 接口集成

SM2 身份签名、密钥交换与确认由 gmsm 接口完成；SM3 用于阶段摘要、HMAC 与 HKDF；SM4-GCM 用于记录认证加密。接口适配保留身份标识、ZA / SM3、签名编码转换、公钥解析与错误检查等成本。[4][5][6][7]

SM2 签名对 e = SM3(ZA ∥ M) 计算 (r, s)，验签核对相应曲线关系；握手则对域分隔后的转录结构签名。SM3 的 64 轮压缩不是本作品创新，原有标准说明伪代码移至附录 C，供核对依赖接口时参考。

表2.3 原语集成责任与验证对应

接口责任	实现处理	对应验证
SM2 身份与编码	保留 ZA、UserID、签名 r∥s 与 ASN.1 转换及公钥解析	所选向量、4 项外部对照；E04
SM2 交换与确认	角色、公钥、身份和 S1 / S2 与当前握手关联	TC-02、TC-05—09
SM3 派生	一次 Extract，按标签和阶段上下文多次 Expand	§2.1.7；密钥调度用例
SM4-GCM 记录	使用方向密钥、Nonce、AAD 与认证失败处理	TC-04、TC-10—13；E05/E10

2.1.6 Suite 2 四步握手与双方材料状态

A 表示设备客户端，B 表示网关。双方长期签名与协商身份来自可信配置；每次握手创建临时材料。m1—m4 为实际编码消息，SessionEstablished 是本地状态，不是 m4 的附加字段。

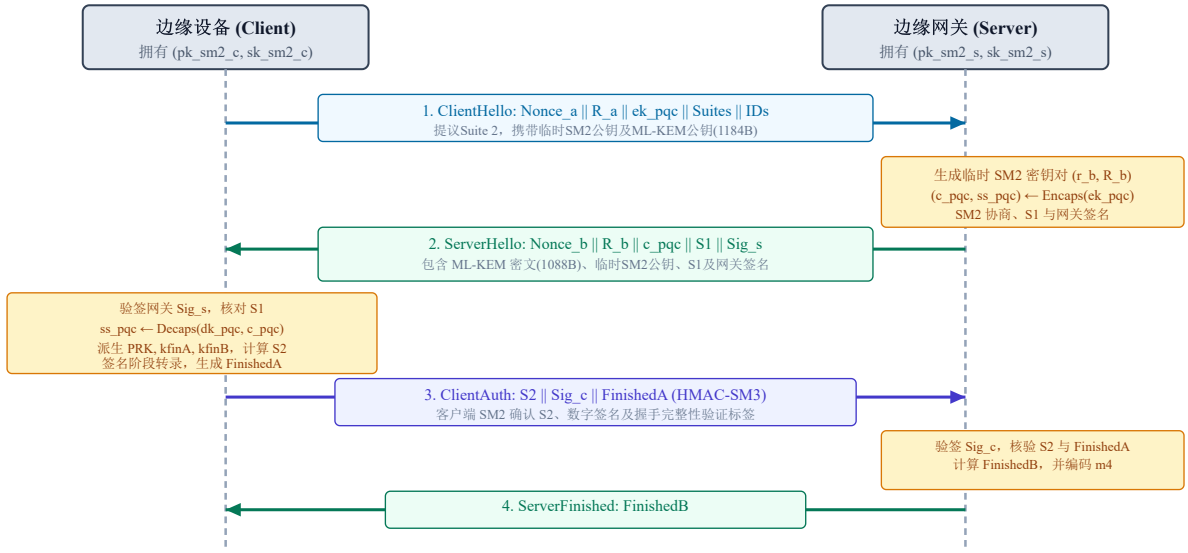


图2.3 Suite 2 四步混合握手

客户端在 m1 提交临时 SM2 公钥和 ML-KEM 公钥；网关在 m2 返回 KEM 密文、SM2 确认及身份签名。客户端检查后发送 m3，网关完成身份、S2 和 FinishedA 核验后发送 m4；应用材料在完整 T4 上派生。

表2.4 四步握手、秘密材料与公开发送内容

阶段	客户端 A：新增 / 使用材料	网关 B：新增 / 使用材料	公开消息或动作
准备及 m1	临时 SM2 私钥 r_a；ML-KEM dk_{pq}；N_a	读取可信配置，检查客户端身份与提议	m1：身份 / 套件、N_a、R_a、ek_{pq}
生成并发送 m2	等待并接收 m2	临时 r_b；Z_{sm2}、Z_{pq}；S1、Sig_B	m2：N_b、R_b、c_{pq}、S1、签名及协商字段
m2 已编码 / 处理完成	检查 m2 后得到 Z_{sm2}、Z_{pq}、PRK、T2、kfinA/B	m2 写出后得到 PRK、T2、kfinA/B	双方保留 m1、m2 的实际字节
m3：ClientAuth	计算 S2、Sig_A、FinishedA；使用 kfinA	核验客户端身份、S2、FinishedA	m3：ClientCore、Sig_A、FinishedA
m4：ServerFinished	接收并核验 FinishedB	使用 kfinB 计算 FinishedB 并发送	m4：FinishedB
T4 与会话接纳	核验 m4 后：双向应用密钥、方向前缀、SID	写出 m4 后：双向应用密钥、方向前缀、SID	本地创建可用 Channel；秘密不作为消息发送

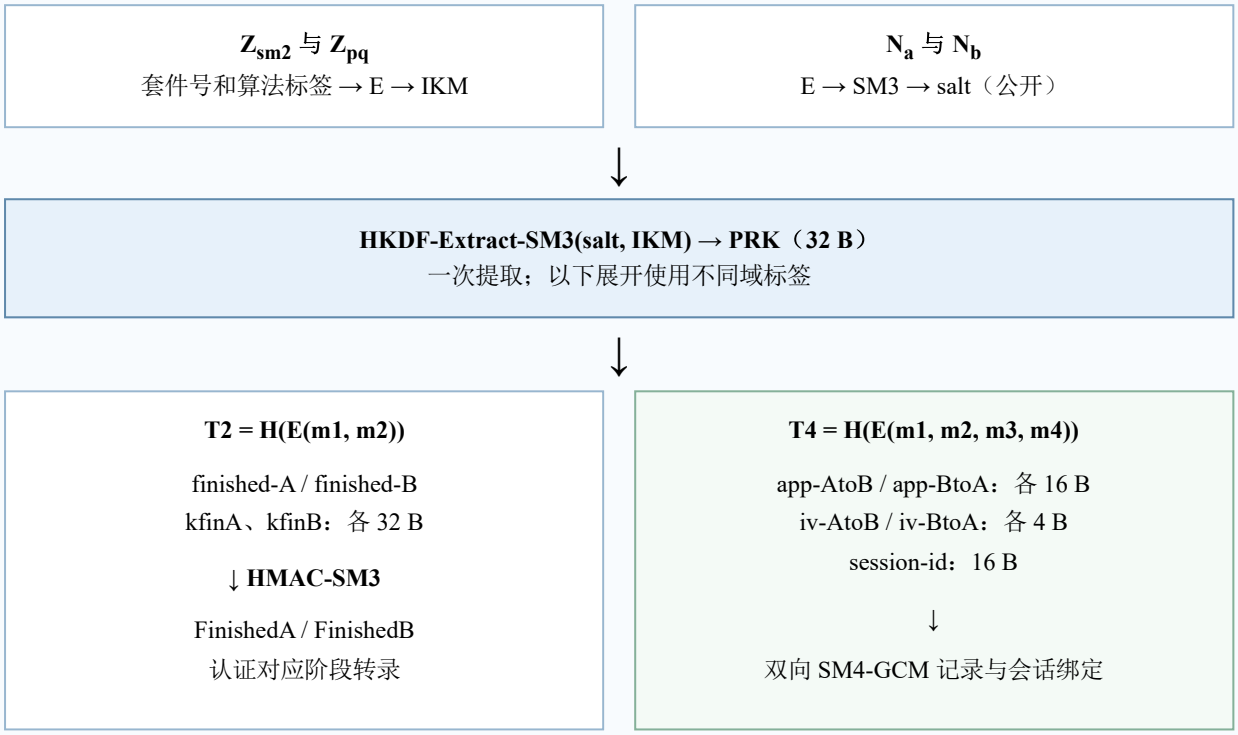
表中“新增 / 使用”不是按消息人为重新生成已存在密钥：kfinA/B 在 T2 可用后即派生，m3、m4 使用已有密钥计算标签。N_a、N_b 为公开握手随机数；dk_{pq}、临时私钥和共享结果留在本地。处理顺序与 source/internal/handshake/client.go、server.go 对应。

2.1.7 T2/T4 分阶段转录与密钥调度

密钥派生遵循RFC 5869的Extract与Expand结构，本实现以HMAC-SM3实例化，并将阶段转录、域分隔与用途标签按协议编码作为输入。[10]

E 为 cryptosuite.Encode 的域分隔、长度编码，H 为 SM3。以 Suite 2 为例：两份共享结果进入带算法标签的 IKM；公开随机数经哈希形成 salt，而不是将它们等同于秘密熵。PRK 只提取一次。

```
IKM = E("edgehybrid/v1/ikm", u16(Suite), "sm2", Zsm2, "mlkem768", Zpq)
salt = H(E("edgehybrid/v1/salt", Na, Nb))
PRK = HKDF-Extract-SM3(salt, IKM)
T2 = H(E("edgehybrid/v1/t2", m1, m2))
T4 = H(E("edgehybrid/v1/t4", m1, m2, m3, m4))
Expand(label, T, n) = HKDF-Expand-SM3(PRK, E(label, T, u16(n)), n)
```



图中 E 的域标签为便于阅读而省略；精确输入与长度编码以上下代码及表2.5为准。

图2.4 一次提取、分阶段展开的密钥调度结构

表2.5 派生标签、阶段上下文与材料长度

用途 / 标签后缀	上下文	长度	含义
finished-A / finished-B	T2	各 32 B	分别作为 FinishedA / FinishedB 的 HMAC 密钥
app-AtoB / app-BtoA	T4	各 16 B	两把 SM4-GCM 方向应用密钥
iv-AtoB / iv-BtoA	T4	各 4 B	两方向的 Nonce 前缀
session-id	T4	16 B	绑定进记录头的会话标识 SID

全部 Expand 标签带 edgehybrid/v1/ 前缀。Suite 1 的 IKM 只包括套件号、sm2 与 Z_{sm2}，并拒绝不应出现的后量子共享输入。Finished 密钥不是 SM4 流量密钥，Finished 标签也不是直接截取的 KDF 输出。

```
D_A = H(E("edgehybrid/v1/t3core", m1, m2, ClientCore, SigA))
FinishedA = HMAC-SM3(kfinA, E("edgehybrid/v1/confirm-A", D_A))
D_B = H(E("edgehybrid/v1/t3", m1, m2, m3))
FinishedB = HMAC-SM3(kfinB, E("edgehybrid/v1/confirm-B", D_B))
```

身份签名输入分别为 E("edgehybrid/v1/server-auth", m1, ServerCore) 与 E("edgehybrid/v1/client-auth", m1, m2, ClientCore)。网关写出 m4 后，客户端核验 FinishedB 后，才按 T4 派生应用材料并接纳会话。认证、确认和派生输入不包含自身输出。

协商字段篡改可能首先触发结构、身份签名或 SM2 确认失败；到达 Finished 的路径再执行对应确认检查。E09 按实际拒绝位置计数，不用“哈希雪崩”替代安全论证。

2.1.8 双向记录保护与严格序号

Key / Nonce。两个方向分别使用 16 B SM4-GCM 密钥。Nonce = 4 B 方向前缀 // 8 B Seq；前缀来自 T4 派生，Seq 在当前方向、Channel 和同一流量密钥内单调递增。Epoch 与 SID 在记录头中，不占 Nonce 位。[7][11]

AAD 与记录。33 B 记录头作为 AAD，绑定版本、套件、业务类型、方向、SID、Epoch 和 Seq；密文与 16 B 标签跟随其后。完整线格式见表1.5。

顺序与拒绝。接收端只接受 seq == next 的记录，并在 AEAD 核验成功后提交 next++。旧序号、跳跃和乱序返回错误，认证失败不提前推进状态；不采用位图滑动窗口。

清单2.1　接收端严格序号与认证后提交（生产源码节选）

```
// internal/record/record.go（节选，实际实现，非示意）
// 接收端：记录头逐字节比对 + 严格 seq == next + AEAD 认证后提交
func (r *Receiver) Open(b []byte) (byte, []byte, error) {
    ...
    kind := b[3]
    seq := binary.BigEndian.Uint64(b[25:33])
    want := header(r.m, kind, seq)
    for i := 0; i < HeaderSize; i++ {          // 记录头必须逐字节一致（作为 AAD）
        if b[i] != want[i] { return 0, nil, ErrRecord }
    }
    if r.next >= r.limit { return 0, nil, ErrLimit }
    if seq != r.next {                         // 旧序号 / 跳跃 / 乱序 -> 拒绝，无滑动窗口
        return 0, nil, ErrReplayOrOrder
    }
    p, e := r.a.Open(nil, nonce(r.prefix, seq), b[HeaderSize:], b[:HeaderSize])
    if e != nil { return 0, nil, ErrAuthentication }
    r.next++                                   // 认证接受是接收状态唯一前进点
    return kind, p, nil
}
```

换钥按 MaxRecords、MaxAge 或明确操作触发：关闭旧 Channel → 完整新握手 → 新会话接纳 → 恢复业务。新 SID 与计数重置需配合新密钥派生使用，不由 SID 改变单独证明安全；本实现不恢复旧会话流量密钥。

2.1.9 面向工业控制语义的因果确认与审计证据

本机制解决的是“数据成功写入 socket 不等于业务操作完成”的语义问题。操作依次记录排队、写入、写出和按业务核验后的确认；错误、超时、未确认以及迟到确认另外保存。

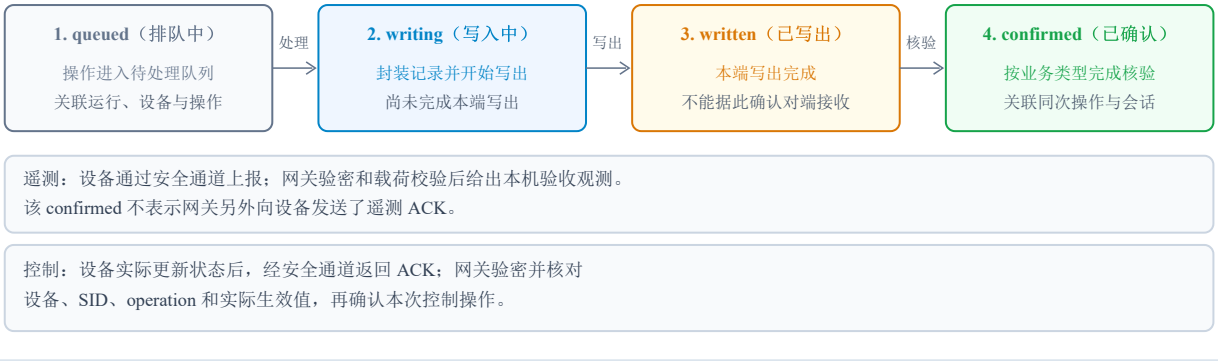


图2.5 四态操作与两类业务确认

表2.6 两类 confirmed 的证据含义

业务	完成判据	不能由它推出的结论
温度遥测	网关验密、载荷与身份检查后记录 telemetry_accepted，并关联当前运行、设备、SID 与样本	不是额外向设备发送遥测 ACK；不测量传感器精度。
间隔控制	设备更新实际间隔，回传 AEAD 保护 ACK；网关核对设备、SID、操作与生效值	不是逐条 SM2 签名；不是物理执行器动作证据。
异常确认	不匹配、旧会话、应用失败和缺失 ACK 按状态保留；迟到可标 late_confirmed	unconfirmed 不等于肯定未执行，不能盲目自动重复下发。

链式审计摘要对选定公开事件有序计算，而非只处理 confirmed 事件。令 U 为 UTF-8 编码、H 为 SHA-256；d_i、e_i、v_i、s_i 分别为事件编号的十进制文本、endpoint、device 和 stage：

$$R_0 = H(U(\text{run_id}))$$

$$B_i = U(d_i + ":" + e_i + ":" + v_i + ":" + s_i)$$

$$R_i = H(R_{i-1} \mathbin{//} B_i), \quad \text{ledger_root_sha256} = \text{hex}(R_m)$$

前一个根以原始 32 B 输入下一步，不使用 64 字符十六进制文本；run_id 仅在初始根加入一次。+ 表示上述字段字符串连接，// 表示字节串拼接。温度、完整载荷和 operation_id 不在该元数据链的覆盖范围；完整文件另以可信文件哈希核对。摘要信任条件见 §2.1.10【安全边界】。

2.1.10 协议安全假设与工程边界分析

2.1.10.1 原语与协议安全依据

ML-KEM-768 的参数与安全类别按 FIPS 203；模格问题、KEM 变换及混合机制的通用分析分别参考标准与研究文献。公开攻击成本估计依模型，不作为严格攻击下界。协议采用原语并不自动继承完整认证密钥交换证明。[3][12][13][8][9]

安全假设与评价范围：Suite 2 以有效身份认证、安全随机源、秘密管理及组合派生条件为前提。身份认证采用 SM2；完整 AKE 归约与机器形式化验证、全调用链常数时间及功耗 / 电磁侧信道评估尚待完成。链式摘要和文件哈希以独立保留的可信基准为核对依据；同时可改写记录和基准的本机管理员属于信任范围。

2.1.10.2 实现来源与团队贡献

表2.7 上游原语、团队实现与声明范围

层次	来源或模块	贡献 / 核对范围
ML-KEM-768	Go crypto/mlkem	调用标准参数接口；上游 NTT、采样及模约简不算团队自研。
SM2/SM3/SM4	github.com/emmansun/gmsm v0.44.1	保留上游许可证；团队完成接口、编码及上下文集成。
混合协议与记录	internal/handshake；internal/record	套件策略、四消息、T2/T4、方向密钥、严格序号与失败路径。
业务与证据	internal/app；internal/live；internal/exports；internal/evidence	业务确认、生命周期、原始事件与复现工具。链式审计摘要的链根 ComputeLedgerRoot 属 internal/exports；internal/evidence 负责解析与运行证据一致性及复算，不持有密钥材料。
发布与许可	source/LICENSE.txt；THIRD_PARTY_NOTICES.md；docs/licenses	项目权利声明与第三方许可分别适用；报告不自动授予开源许可。

2.1.10.3 关键风险与工程处置范围

表2.8 关键风险、当前处理与剩余假设

风险	当前机制与证据	条件与范围
随机数失效	接口保留安全 RNG；临时密钥、封装及握手随机数参与每次建钥	依赖随机源与运行环境；没有完成全部熵源失效注入。
长期身份秘密泄露	长期签名 / 协商身份与临时会话材料分开；支持轮换、吊销和退役	未来冒充风险需撤销与重新配置；前向保密还需模型和清理假设。
协商篡改与重放	身份 / 确认失败不放行业务；Seq 认证后推进	E09/E10 及所选记录用例支持具体拒绝路径。
拒绝服务与资源消耗	结构长度上限、握手预算、安全失败与有界公开事件	这些限制不保证任意负载下可用性；不将拒绝等同于一般 DoS 免疫。
密钥清理与本机管理	句柄失效、依赖清理；管理入口受本机授权与请求守卫约束	长期私钥标量以本地文件保存，当前 Windows 分支不自动收紧 ACL，运行目录访问权限属于部署前提。句柄销毁不保证全部库内副本或物理介质擦除；跨进程身份管理要求单写者，本机管理员仍属信任边界。
物理侧信道	依赖实现与平台须另作评估；公开分析用于说明风险	未执行功耗或电磁攻击评估；相关研究不作为本项目防护成绩。[14]

2.1.10.4 组合安全假设与失效影响

协议分析围绕建钥分支、身份认证、会话匹配和业务接纳展开。表2.9列出组合假设、具体实现及失效影响，为进一步建立形式化模型提供接口。

表2.9 组合安全条件与失效影响

条件或失效事件	当前设计对应	可以解释的范围
建钥分支与组合派生	SM2、ML-KEM 共享结果带算法标签和长度进入 IKM；一次 Extract 与按用途 / 阶段 Expand。	两分支依赖测试证明所测输入影响输出；“一分支失效仍安全”还依赖剩余分支、认证、组合器及攻击模型的正式分析。
协商、身份和会话匹配	身份签名覆盖对应协商转录；SM2 确认与 Finished 核验完成后接纳；应用材料绑定 T4。	篡改用例支持所到达路径的拒绝；需进一步形式化说明伙伴会话、未知密钥共享、重放与状态对应。
长期 SM2 身份密钥泄露	长期身份与临时材料分开；提供轮换、吊销、旧会话清退和新握手。	未来冒充能力与历史流量保密分别分析；后量子建钥不能替代后量子身份认证，不能据此声称长期密钥泄露无影响。
随机源或临时材料泄露	使用安全随机接口生成握手随机数和临时材料；失败不静默回退。	安全依赖实际随机源和秘密管理；尚无全熵源失效矩阵或全部运行时副本擦除保证。
记录与控制结果	方向密钥、Nonce、AAD、严格 Seq 与匹配业务 ACK 共同约束接纳。	认证通过表示该记录通过当前会话的认证校验；业务 ACK 证明所测软件状态，不推出实体执行器动作或跨重启严格一次执行。

2.1.11 Android 实机验证终端

除默认的本机模拟演示外，作品增加可选的 Android 实机验证入口。Windows 电脑运行独立网关，通过移动热点与摩托罗拉 X30 连接；手机在 Termux 中运行 Android/arm64 设备程序，通过 Termux:API 获取电池温度并控制手电筒。该入口沿用 Suite 2 的身份认证、混合建钥和记录保护，没有另建明文业务通道。本机管理网页继续只绑定 127.0.0.1，热点地址仅开放设备业务端口。

首次部署时在电脑生成独立的 GW001 与 D001 身份、可信配置和手机连接配置。手机安装包仅导出 D001 的设备私钥及公开信任信息，网关私钥保留在电脑。公开软件包不预置这套身份，复现者使用生成脚本创建自己的配对；原有模拟演示仍可在没有手机时完整运行。

手机采集器解析真实电池 API 的返回值，将电池温度编码为遥测记录后通过安全通道上报。采集失败单独记录，不填充模拟温度。手机收到有效上报间隔控制后先调整采集计时器，再发送带同一操作编号的安全 ACK。电脑验证回执后确认间隔设置；接口调用与系统调度耗时会叠加到实际采集周期中，因此该功能不宣称严格实时调度。

手电筒作为控制生效后的可见提示，只对新的控制操作触发，不随每次温度上报闪烁。兼容时序为预关闭后等待 1 秒、开启 1 秒、关闭后等待 2 秒，单独工作线程串行执行，避免阻塞后续 ACK 与采集。同一操作的重试不重复触发；提示队列有界，异常单独记录。接口返回与物理亮灯分别验收，间隔 ACK 不代表对执行器状态的独立测量。

2.2 运行结果

本节从准入、业务确认、多身份、证据导出、身份维护与实验隔离六个任务说明工作台。原有截图反映归档版本，新版详情抽屉另见 §2.2.7。

2.2.1 工作台准入与便携运行

解压完整运行套件并保留目录结构，使用 runtime/启动交互平台.cmd 启动。浏览器访问控制台打印的 PAGE_URL，输入本次一次口令。管理入口由本机回环服务、Cookie 和请求守卫承载；关闭页面不等于结束后台进程。



图2.6 工作台管理授权与口令准入（原始截图）

8 个已编译程序及随附配置构成运行包；运行预编译版无需 Go、Python、Node.js 开发工具链，本机 Web 界面仍需要浏览器。公开回执记录运行身份，口令、Cookie、私钥等敏感材料不作为公开证据。

2.2.2 温度验收、控制 ACK 与报文字段

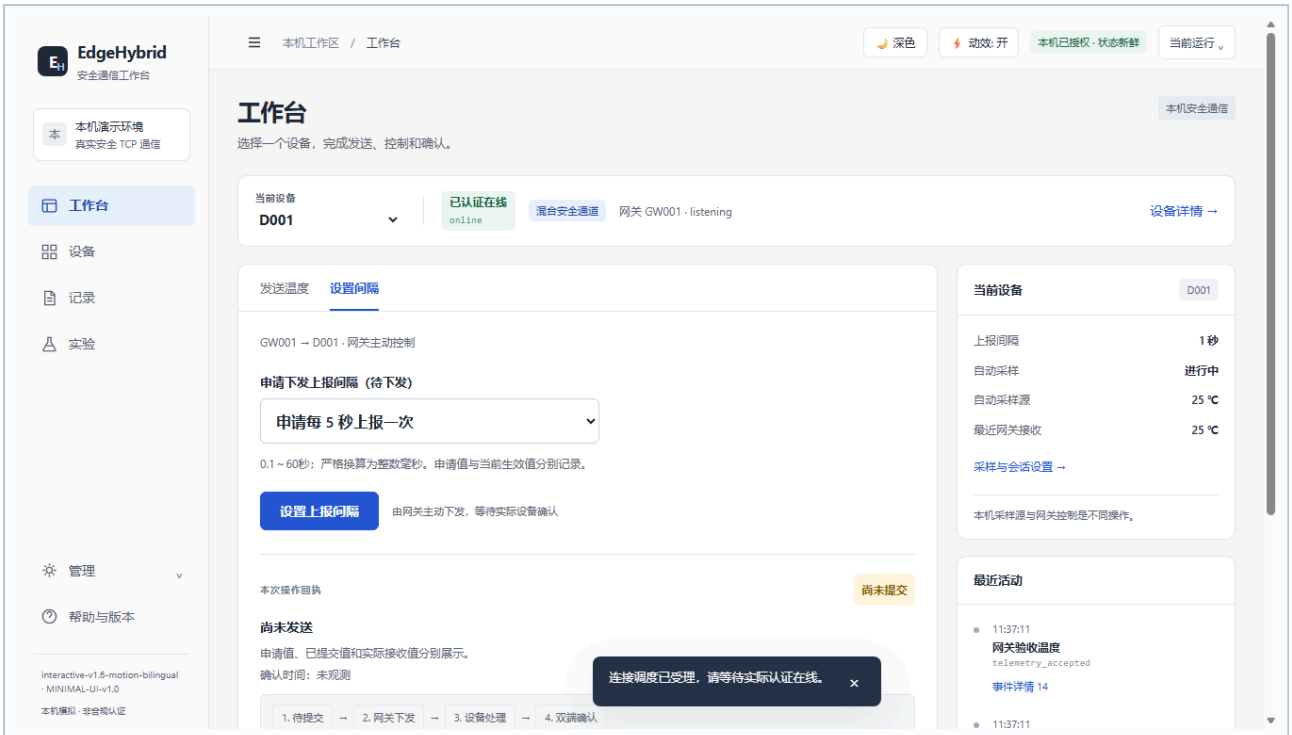


图2.7 D001 工作台与分类型业务确认（原始截图）

D001 的温度由安全通道上报并由网关验收；间隔控制要求设备更新实际调度状态、返回 ACK 并由网关核验。界面区分申请值与生效值，业务操作以 run_id、device、SID、operation_id 或 sample_id 关联。

表2.10 业务操作关联字段与判断方法

核对对象	证据与判据
设备、运行与会话	同一 RUN_ID、设备和 SID 下关联事件，不能把不同运行日志拼成一次闭环。
温度	网关 telemetry_accepted；不是设备额外收到遥测 ACK。
间隔	设备实际生效值＋匹配操作 ACK；HTTP 受理或 written 不能替代 confirmed。
多身份	20 身份共存与各自会话；GUI actor 与命令行进程结构区分。

以下三种报文仅用于字段解释。L_{pt} 为实际编码明文的字节长度，线上传输相同长度的密文；Length 不含自己的 4 B。示例占位内容不是某次实测抓包。

```
uint32_be(51 + L_pt) || wire.Version(1 B) || wire.Kind(1 B)
|| Header(33 B, AAD) || Ciphertext(L_pt B) || Tag(16 B)

Telemetry: RecKind=1, Direction=1 (设备→网关)
Control:   RecKind=2, Direction=2 (网关→设备)
Ack:       RecKind=3, Direction=1 (设备→网关)

Header = RecVersion(1) || Suite(2) || RecKind(1) || Direction(1)
      || SessionID(16) || Epoch(4) || Seq(8)
Nonce  = DirectionPrefix(4) || Seq(8)
```

2.2.3 多身份管理与逐目标批量操作

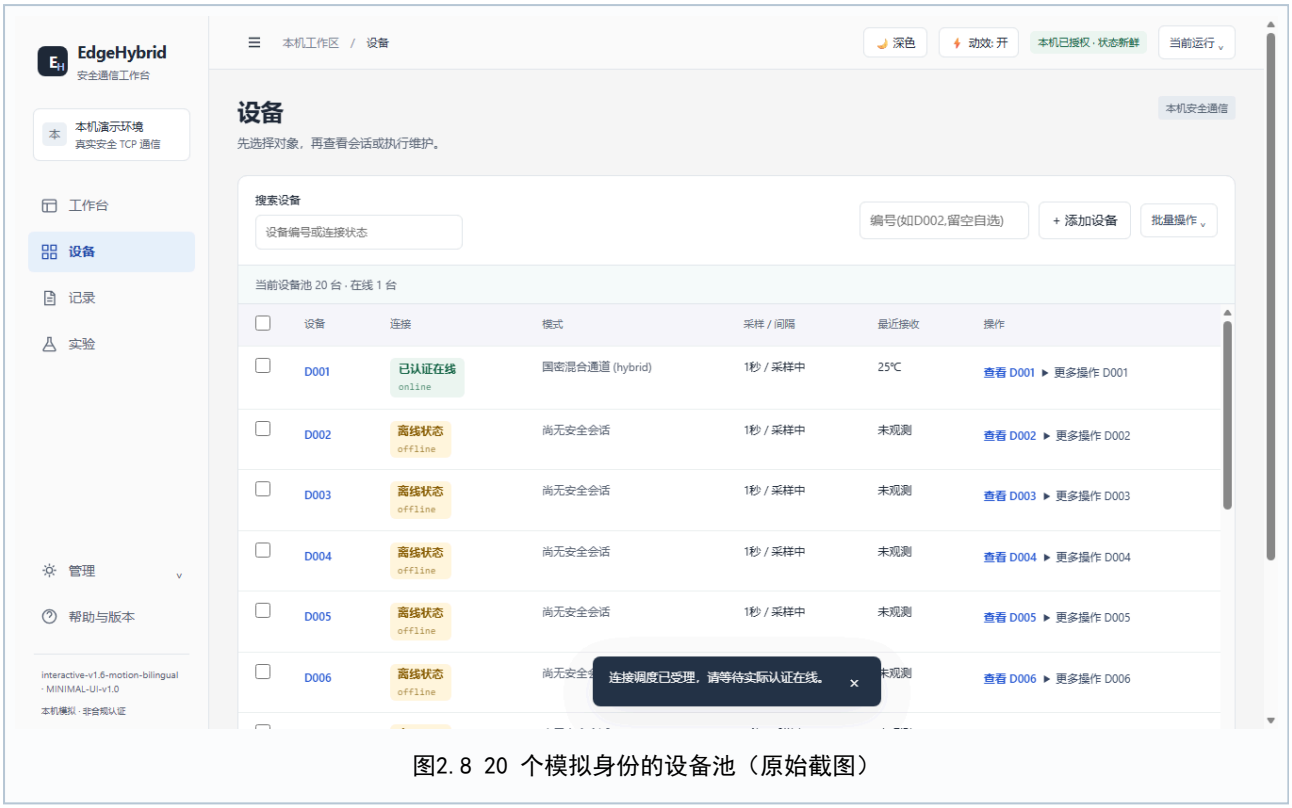


图2.8 20 个模拟身份的设备池（原始截图）

GUI 中 D001—D020 为具有独立身份和会话的模拟端点，由控制台内的软件 actor 承载；fleet 的命令行联调另用并发任务。界面提供添加、连接、退出、排序与过滤，并记录选定集合的逐目标结果。

E06 验证现有界面逐目标提交并等待终态；G04 验证单目标受控断开后其余目标继续完成控制。两者分别是 UI 批量测量与功能故障试验，不能将 G04 的结果解释为自动故障检测。数值统一见 §3.3。

2.2.4 链式审计摘要与证据导出

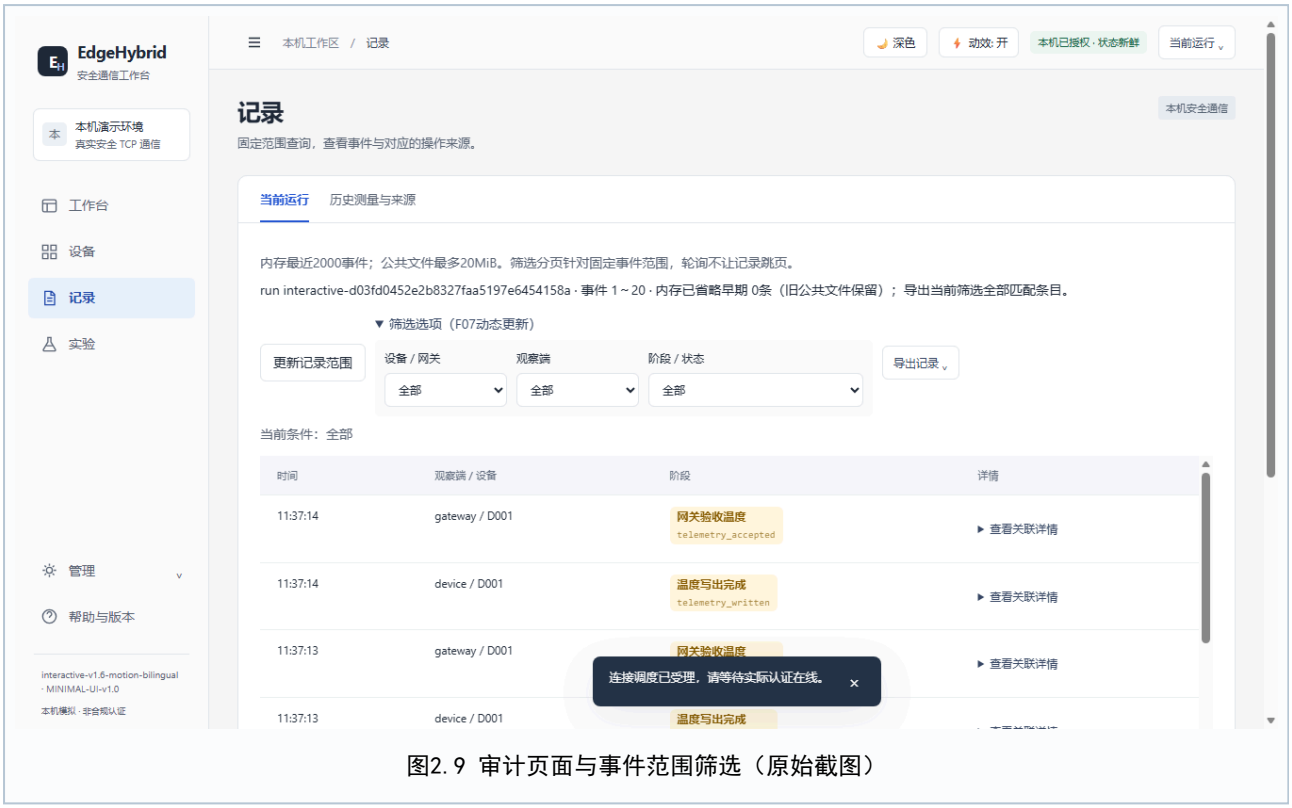


图2.9 审计页面与事件范围筛选（原始截图）

审计页面按端点、设备和阶段筛选公开事件；固定范围后导出 JSON、CSV 或 HTML。内存保留最近 2,000 条公开事件，公开落盘文件上限 20 MiB，以控制相关日志资源。摘要计算遵循 §2.1.9，而非覆盖全部业务字段。

```
{
 "schema_version": "interactive-export-v1",
 "run_id": "<实际运行标识>",
 "include_payload": false,
 "source_manifest_sha256": "<对应源码清单哈希>",
 "event_count": 1,
 "earlier_events_omitted": 0,
 "stage_counts": {"telemetry_accepted": 1},
 "events": [{
  "schema_version": "<实际事件模式标识>",
  "run_id": "<同一运行标识>",
  "event_id": 16,
  "at": "<实际时间戳>",
  "endpoint": "gateway",
  "device_id": "D001",
  "stage": "telemetry_accepted",
  "detail": "telemetry_accepted"
 }],
 "ledger_root_sha256": "<按所选事件元数据计算的真实根>"
}
```

说明：尖括号为占位，不能作为可验证导出。遥测接受是网关本机观测，不增加 ack_verified 字段，也不表示网关另发遥测 ACK。

导出“已生成”和文件“已保存”分别判断；完整文件哈希、选定范围及运行标识共同用于复核。元数据摘要与测试事件数组哈希的对照范围见 G01，不把正常导出成功当作任意篡改负例。

2.2.5 长期身份维护与完整会话更新



图2.10 网关长期身份维护窗口（原始截图）

长期身份维护采用准备验证、停止准入 / 关闭旧会话、CAS 提交、加载新世代、明确重连与尽力清理的受控流程。网关操作需二次确认，单设备可执行 rotate、revoke、retire；长期 Generation 与会话 Epoch 分别管理。

临时会话换钥依据 MaxRecords、MaxAge 或明确操作执行完整新握手。G3 与 G07 检查新旧 SID 和新会话业务；G06 检查测试宿主重启后的吊销与身份标识。它们的实际输入、次数及观察对象在 §3.5 单列，不附加无中断或物理掉电结论。

2.2.6 安全实验与版本化证据入口



图2.11 安全实验室与隔离验证入口（原始截图）

安全实验与在线通信采用前置互斥：仍有在线或连接中设备时，须先明确断开再执行实验。白名单任务记录真实退出码与结构化输出；历史测量视图同时列出生产源码清单、二进制标识及批次来源。

本机工作台统一呈现协议状态、业务回执和验证任务。完整操作顺序见第4章，原始截图与证据索引见 §3.6。

2.2.7 分层详情与容量可视化

详情抽屉采用“概览—摘要—关联编号—技术记录”的阅读顺序。运行概览将操作记录、换钥记录、日志空间和最近事件分别显示为用量 / 上限卡片，进度条辅助比较；队列、导出与任务仅显示已知配置上限。长编号与公开原始JSON收在展开项中，便于普通操作与技术核对各取所需。

设备详情按连接状态、最近会话模式、上报间隔和采样信息展示；操作详情按实际时间戳绘制处理进度。缺失值显示“未观测”，合法零值保留，状态过期显示上次观测标记。抽屉沿用工作台的蓝色强调、白色卡片、圆角边框与明暗主题；刷新保留展开状态，关闭后将键盘焦点返回入口。

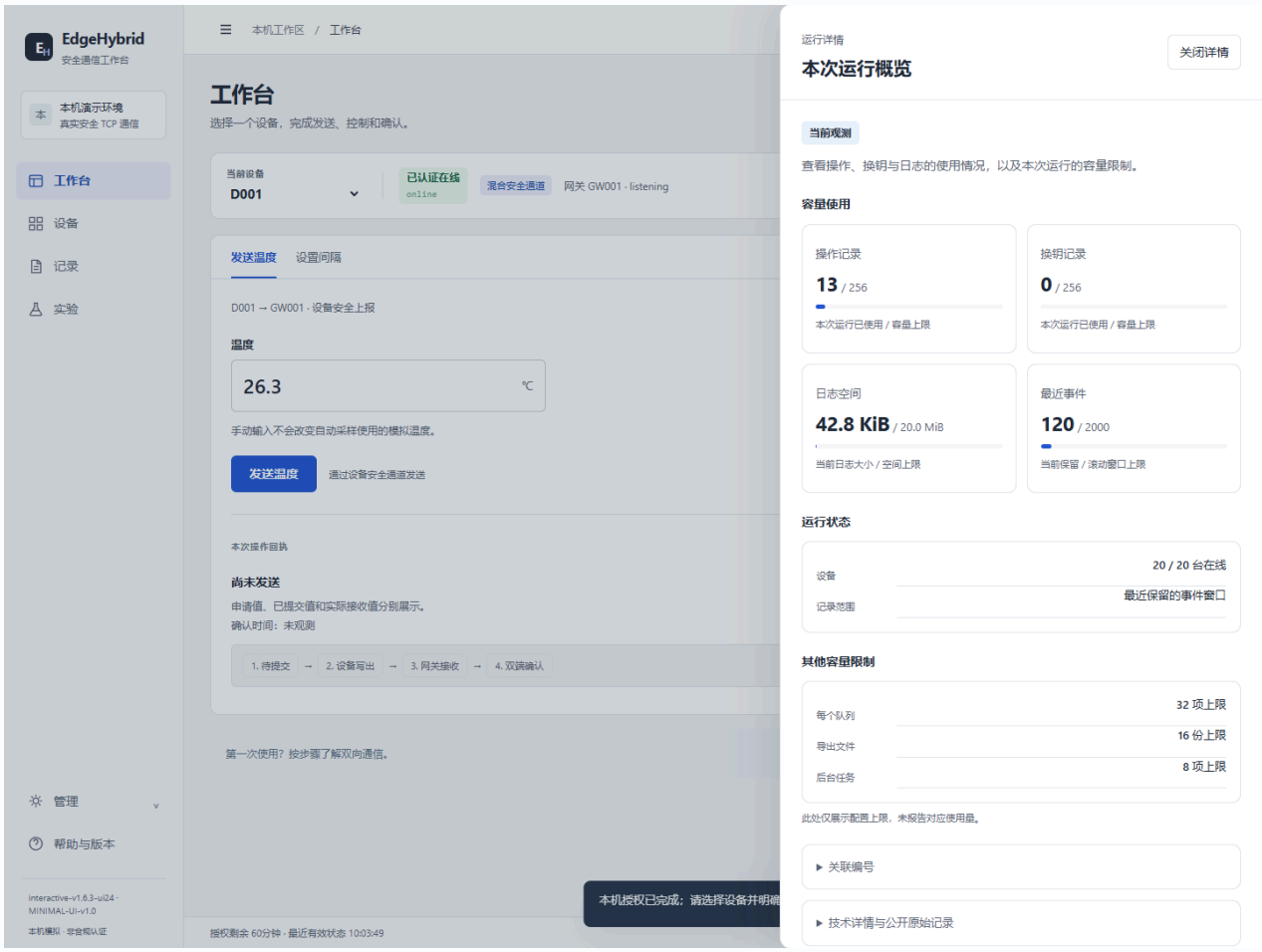


图2.9 新版运行详情：20台设备在线，13条已确认控制操作；该图展示交互验收运行，历史性能按原批次保留。

2.3 技术指标

技术指标按完整握手、已建通道业务、原语计算、用户批量流程和进程资源分别定义。表3.11集中列出主值与来源，表3.18列出团队参考目标；测试方案说明观察区间、样本分母与分位算法，性能测试及测试数据章节给出完整结果。界面显示的容量上限属于运行配置，按实际使用量呈现。

3. 系统测试与结果

3.1 测试方案

实验围绕功能正确性、握手与业务成本、资源使用及工程质量展开。表3.1列出验证问题和观察指标，历史测量、补充试验与独立对照按批次归档。

历史冻结 固定 M5 等已归档批次　**本轮补测** E / G 系列　**证据复用** 已完成结果的再次核对

表3.1 验证问题、指标与证据总矩阵

类别	编号	验证问题	主要指标 / 断言	证据入口
功能	G3；G01—G07	换钥、异常业务、断链、重启是否按机制处理	新 SID、匹配 ACK、无误确认、配置状态	§3.5；focused_retest_v11
握手性能	历史 T/H/P	三种实现的建链成本	均值 / 中位数 / P95；字节数；成功/执行	§3.4；historical_m5_embedded.json
业务性能	E01/E06	已建会话 RTT 与用户批量耗时	ACK RTT；逐目标终态；失败分母	§3.3.1/3.3.3
原语性能	E02—E05	实际密码适配器的计算成本	ns/op、µs/op、MB/s、B/op	§3.3.2；primitives_formal_01
进程资源	E07；历史资源批次	哪个进程、哪个窗口占用资源	PID；峰值工作集；CPU 时间	§3.3.3/3.4
安全行为	E09/E10	协商篡改与记录损坏是否拒绝	拒绝阶段；可用 Channel；业务副作用	§3.5.1；tcp/ber_formal_01
工程质量	Fuzz/race/E08	解析、并发与静态告警如何处置	崩溃/断言；竞争报告；逐项处置	§3.2.6/3.5.3
对照与复现	E11；外部 SM2	独立实现及历史证据能否对应	配置、原始文件哈希、外部输出	§3.4/3.6

3.1.1 环境、版本与执行批次

历史环境按原记录为 Windows 11 / amd64、Intel Core i7-11800H、本机回环。每个批次保存自己的环境和程序身份，性能采样串行执行。后续源码修改与工具链重建只建立新的发布身份，不倒改历史性能日期或 run_id。

表3.2 版本身份与结果归属

来源标签	数据 / 程序	身份与计量范围
历史冻结	M5：T/H/P 握手、批次 CPU/内存、业务 Goodput	源码清单 fad0abe7…；plan=m5-formal-20261001-v1；各数据自带 run_id。
本轮补测	E01—E07 性能与相关质量批次	保留 Go 1.27.1 测量标识；不可改称 Go 1.27.2 重建后的实测。
本轮补测	E08 处置与发布构建	interactive-v1.6.2-e08fix1；清单 02863dd2…；8 个 EXE 的构建记录为 Go 1.27.2。

来源标签	数据 / 程序	身份与计量范围
本轮补测	G01—G07 定向功能验证	Go 1.27.2 Windows 测试宿主；7 组各 3 次，共 21 条正式命令。
证据复用	定向 race、4 项外部 SM2、G3 和 E11	按已归档配置复用；重复核查不增加独立测试数量。

计量范围：原语、握手、已建通道 RTT、UI 批量、业务 Goodput 和进程资源各有明确观察区间。各批次分别保存环境与版本，现场网络和目标 MCU 需建立对应测量。

3.1.2 软件输入、时钟与证据采集

测试使用本机 TCP、模拟身份、握手字段篡改、记录比特翻转与受控连接中断。E01 用同进程 QPC 单调时钟；E06 用 performance.now() 记录用户可见批量流程；E07 按 PID 与映像身份采样。命令、stdout、stderr、退出码及原生事件保留原始文件。

历史握手保留 0 ns 观测（T/H/P 分别为 131 / 47 / 33 条）。原语 ns/op 是基准循环的批内均值，跨 5 个独立进程取中位数，不是单次调用 P50。CPU 与峰值内存归属于进程批次，未按每笔握手分摊；完整口径见指标主表。

3.1.3 计时分辨率与高精度复核

历史 T/H/P 三组各保留 1,000 条成功样本。经采样清单核对，T/H 使用 time.Now() 与 time.Since(...).Nanoseconds() 写入整数纳秒，输出前未按毫秒取整。对应 Go 1.27.1 的 Windows/amd64 单调时钟路径读取系统中断时间；两次读取处于同一次更新内时可产生零差值。[15]

历史分布中同时存在零值与约 0.503 ms 的最小正观测，符合离散更新造成量化的表现。最小正样本反映本批观测尺度；具体零值还可能受采样和调度条件影响，旧环境没有逐条重演。统计保留全部观测，表3.3给出零值比例与原均值。

表3.3 历史握手零值与最小正观测（离线复算）

模式	记录数	零耗时数 / 比例	最小正观测	报告均值
T	1,000	131 / 13.1%	0.5031 ms	0.9243 ms
H	1,000	47 / 4.7%	0.5033 ms	1.1129 ms
P	1,000	33 / 3.3%	0.5028 ms	1.2232 ms

H 与 P 的历史均值差约 0.1103 ms，需结合表3.3的量化现象理解。为单独测量亚毫秒区间，完整握手复测采用 Windows QPC：记录计数差和计数频率，再换算为时间。本批频率为 10 MHz，对应 100 ns 的计数步长；纳秒表示法与实际分辨率分别说明。QPC 握手结果见表3.26a，E01 的 QPC 测量对象则为已建通道业务 RTT。

完整握手复测中，混合模式平均 1.1479 ms、P95 1.4731 ms，正式样本均为正值。该批与历史测量各自保留环境、原始记录和观察区间；QPC 解决高分辨率计时需求，操作系统调度和宿主负载仍属于实验条件。

3.2 功能测试

沿用已归档 TC 编号，便于与旧日志对应；未纳入本次范围的编号不重排为新测试。以下各表沿用已归档并核验的输入与结论；G 组新增证据与 E 系列原始性能分开记账。

3.2.1 基础密码原语与所选向量

表3.4 基础密码原语与所选向量（TC-01—04）

用例	验证对象	实际输入或检查范围	结论及边界	状态
TC-01	ML-KEM 尺寸与往返	检查公钥 1,184 B、密文 1,088 B、共享秘密 32 B；执行生成、封装和解封装。	所述尺寸与共享秘密往返一致；不声称测量 2,400 B 私钥编码或全量官方 KAT。	通过（所测范围）
TC-02	SM2 签名、交换与外部对照	所选签名 / 密钥交换用例及四项 Bouncy Castle / OpenSSL 外部对照。	按各用例的输入、确认值和签名验证结果保留；不改称任意附录向量全量逐字节认证。	通过（所测范围）
TC-03	SM3 已知答案	源码中所选固定已知答案与流式输入用例。	对应摘要与已知值一致；未给出十万次雪崩分布成绩。	通过（所测范围）
TC-04	SM4-GCM 标准向量	TestSM4GCMRFC8998Vector；20 B AAD。	对应密文与 16 B 标签吻合；不扩大为 GM/T 0099 全套向量。	通过（所测范围）

3.2.2 会话协商、降级与身份认证

表3.5 会话协商、降级与身份认证（TC-05—09）

用例	验证对象	实际输入或检查范围	结论及边界	状态
TC-05	Suite 2 正常握手	双方按可信配置执行四消息握手与记录通信。	所测握手和通信成功；应用方向密钥各 16 B。功能 PASS 不断言每次握手 <3 ms，时延单列。	通过（所测范围）
TC-06	Suite 1 合法兼容	可信配置显式允许的传统身份执行 Suite 1。	建立传统通道；不是混合失败后静默回退。	通过（所测范围）
TC-07	协商套件篡改	既有 9 个降级变体矩阵中的套件删除、修改或重排。	在实际到达的结构、身份或确认检查处拒绝，不返回可用 Channel。	通过（所测范围）
TC-08	PQC 字段篡改	矩阵中的公钥 / 密文缺失、等长修改。	所测路径拒绝；结构错误、签名失败与等长密文隐式拒绝分开，不能一律归为 Finished。	通过（所测范围）
TC-09	伪造设备签名	所选设备身份签名篡改与认证失败用例。	拒绝认证并不放行业务；不附带自动临时黑名单或硬件封禁结论。	通过（所测范围）

3.2.3 记录认证与严格序号

表3.6 记录认证与严格序号（TC-10—13）

用例	验证对象	实际输入或检查范围	结论及边界	状态
TC-10	记录加解密与损坏拒绝	已归档记录往返、密文 / 标签 / 头部篡改用例。	合法记录往返一致；所测损坏输入拒绝。仅限记录 / 软件处理范围。	通过（所测范围）

用例	验证对象	实际输入或检查范围	结论及边界	状态
TC-11	严格序号与 Nonce	单调序号、方向前缀、预算和乱序边界用例。	按实际断言保留；不声称完成单会话十万条抓包。	通过（所测范围）
TC-12	同序号重放	重复提交已经接受的受保护记录。	记录层返回重放 / 乱序错误，失败不推进序号；不附加 100 ms、静默丢弃或特定日志标签。	通过（所测范围）
TC-13	旧序号与乱序	记录重放 / 重排及旧会话记录用例。	不匹配的序号或会话记录被拒绝，不提供一般 DoS 免疫结论。	通过（所测范围）

3.2.4 因果确认、元数据摘要与身份维护

表3.7 因果确认、元数据摘要与身份维护（TC-14—17）

用例	验证对象	实际输入或检查范围	结论及边界	状态
TC-14	控制结果的因果确认（含异常 ACK 补充）	采样间隔设置与匹配的设备状态 ACK；截留真实加密 ACK、迟到/跨重连旧 ACK、错误 SID / 错误值等负例。	设备更新后网关核验 ACK 才确认；截留的加密 ACK 不使操作被误判为未执行、也不误确认；错误 SID / 值不确认，迟到与旧 ACK 按用例拒绝或标识。不主张跨重启严格一次执行或第三方不可抵赖。	通过（所测范围）
TC-15	元数据链根负例（G01）	对所选范围公开事件元数据（设备、stage、事件顺序、删项）改动后重新计算 ComputeLedgerRoot；并以“仅改温度载荷”作对照。	元数据改动（设备/stage/顺序/删项）均使链根改变、正常重复不变；仅改温度不改变元数据链根，但会改变完整 JSON 文件哈希。可信摘要基准必须保留；不主张无可信锚时防恶意管理员或所有载荷入链。	通过（所测范围）
TC-16	身份吊销	既有生命周期联调与吊销 / 退役定向记录。	保留所测身份准入与持久化行为；不使用外部 CA 或网卡层拦截表述。	通过（所测范围）
TC-17	完整会话换钥	G3：关闭旧通道、完整新握手、新 SID 与新会话业务。	新旧 SID 不同、双端接纳、新会话业务确认；不提供换钥耗时或零丢包结论。	通过（所测范围）

3.2.5 异常输入、受控中断与恢复

表3.8 异常输入、受控中断与恢复（沿用 TC 编号）

用例	验证对象	实际输入或检查范围	结论及边界	状态
TC-18	单目标异常下批量行为（G04）	20 个模拟身份已在线，第 7 目标（D007）真实 Channel 断开；对其余 19 个健康目标逐一控制下发。	20 个目标均被尝试；19 个健康目标控制获匹配 ACK 并确认；故障目标被拒绝、不误确认。测试驱动调用生产 Manager，验证受控断开后的逐目标结果，不是浏览器 UI 计时。	通过（所测范围）

用例	验证对象	实际输入或检查范围	结论及边界	状态
TC-19	越界温度与非法间隔拒绝（G02）	经真实安全通道送入 200 / −100 ℃ 越界温度，以及 0 / 50 / 60001 ms 非法间隔；并含正常对照。	越界温度返回 ErrBusiness、非法间隔被拒绝，正常对照通过。仅覆盖所测输入与正常对照，不含实体传感器或 PLC 跳闸回路。	通过（所测范围）
TC-20	中断后的新握手（G05）	真实 TCP 中继关闭活动连接并阻断 ≥5 s 后重新开放，触发显式重连。	实测停顿约 **5.001 s**；重连执行完整新握手，新旧 SID 不同，新 SID 上温度与控制均获确认。不承诺自动恢复时限，也不代表 IP 丢包率。	通过（所测范围）
TC-21	结构化拒绝与 Fuzz	已有解码边界用例及 §3.2.6 四个各 30 秒的解析器 Fuzz。	所列用例与预算内无已报告崩溃 / 断言失败；不能推出零内存泄漏或全输入正确。	通过（所测范围）
TC-23	软件误码与通道损坏	24,000 次 Bernoulli 记录试验；Channel 指定域单比特损坏 300 次。	变化记录 12,967 条全部拒绝；300 次损坏拒绝并关闭通道，无控制处理或错误确认；非物理误码、无自动重传。	通过（所测范围）
TC-24	进程重启与配置加载（G06）	两个独立 Go 测试宿主进程共用隔离可信目录；核对 D002 吊销状态及 D001 身份世代、密钥标识与重连。	D002 重启后仍被拒；D001 的身份世代、两类密钥标识保持，并以新 SID 完成业务。此项不是正式 GUI EXE 黑盒、物理断电或私钥字节比对。	通过（所测范围）
TC-25	多个身份换钥（G07）	20 个身份经公共屏障发起受控换钥请求；记录相对参考时刻的请求发起时间。	20 份双端接纳回执、新 SID 及每轮 40 次业务确认均有记录。请求经公共屏障发起；本批时间观测不作为严格同步、起跑精度或握手时延结论。	通过（所测范围）

3.2.6 解析器 Fuzz、语句覆盖率与并发检查

四个解析器目标分别运行 30 秒、2 workers，并顺序进入 active fuzzing。下面记录实际执行数和退出结果，不将输入次数解释为不同攻击种类或全协议状态覆盖。

表3.9 四个解析器 Fuzz 结果

Fuzz 目标	预算	实际输入执行数	结果
FuzzSM2PublicInput（internal/cryptosuite）	30 秒 / 2 workers	951,494	无崩溃，退出码 0
FuzzFrame（internal/wire）	30 秒 / 2 workers	2,385,044	无崩溃，退出码 0
FuzzBackendManagementJSON（internal/console）	30 秒 / 2 workers	231,018	无崩溃，退出码 0
FuzzBackendStrictExport（internal/exports）	30 秒 / 2 workers	665,109	无崩溃，退出码 0
合计	4 × 30 秒	**4,232,665**	0 崩溃 / 0 失败

增强测试集增加 5 个测试文件，10 个顶层组、137 个子测试覆盖严格解码、异常 I/O、业务与会话关联、吞吐证据一致性和导出复算，形成表3.10的同源覆盖率对照。

表3.10 同源六核心包语句覆盖率（atomic）

包	同源补测前	补测后	补测后覆盖率
cryptosuite	262/389	262/389	67.35%
evidence	168/471	457/471	97.03%
handshake	705/831	705/831	84.84%
policy	21/30	21/30	70.00%
record	60/63	60/63	95.24%
wire	44/48	44/48	91.67%
六包合计	**1260/1832**	**1549/1832**	**84.55%**

M13 为 84.55%（1549/1832）。同一生产源码与六包插桩口径下，由 68.78% 提升至 84.55%，evidence 由 35.67% 提升至 97.03%。历史 M11＝69.56%（1307/1879）保留，不与本轮百分比直接作算术比较。另测 internal/exports 为 85/88（96.59%），不并入六包统计。覆盖率反映语句执行范围，不构成安全正确性证明。

归档 evidence fuzz 执行 617,175 次，10 秒冒烟执行 375,295 次，均未报告崩溃。定向 EVX race 的 10 组、137 个子测试通过；全仓竞争检测另见表3.26b。4 项可选外部对照与 10 分钟长测按实际 SKIP 记录。测试命令、旧失败及修正回执保存在 verification/final_v17/，便于追踪回归过程。

3.3 性能测试

表3.11汇总主要指标，配套指标文件保存来源、公式和计量范围。M13补充同源增强测试覆盖率，M14补充QPC完整握手结果。各测量保留原批次身份；团队参考目标用于解释实验结果，赛题要求及功能判据分别列明。

表3.11 关键指标主索引

ID	指标	主值	批次 / 口径
M01	混合H握手均值	1.1129 ms	历史M5；1000次连续握手
M02	Suite 2控制RTT P95	0.2645 ms	E01；已建安全会话：请求至ACK核验
M03	SM4-GCM 4096 B Seal吞吐	605.92 MB/s	E05；原语适配器；5次批内均值的中位数换算
M04	SM4-GCM 4096 B Open吞吐	650.78 MB/s	E05；原语适配器；5次批内均值的中位数换算
M05	Suite 2控制RTT均值	0.1474 ms	E01；已建安全会话：请求至ACK核验
M06	ML-KEM KeyGen	53.77 µs/op	E02；五个独立进程批内均值的中位数
M07	ML-KEM Encaps	56.31 µs/op	E03；五个独立进程批内均值的中位数
M08	ML-KEM Decaps	55.15 µs/op	E03；合法密文；五个批内均值的中位数
M09	20身份Suite 2进程峰值组均值	24.12 MB	E07；OS进程生存期高水位，3次均值
M10	20设备UI批量Suite 2中位耗时	19.3856 s	E06；逐目标等待终态的UI耗时

ID	指标	主值	批次 / 口径
M11	六核心包语句覆盖率	69.56 %	历史质量验证；1307/1879语句；非全仓/分支/安全性
M12	混合H握手成功/执行	1,000/1,000 次	历史M5；此历史批次观测
M13	同源六包增强测试覆盖率	84.55 %	EVX；1549/1832；同源基线1260/1832
M14	T/H完整握手QPC测量（H均值 / P95）	1.15 / 1.47 ms	F02实测；QPC测试宿主、同生产源码、本机TCP、两模式各1000/1000成功（T均值0.80 ms / P95 1.06 ms）

3.3.1 控制请求—ACK RTT（E01）

本轮补测 已建立安全会话后，从提交单次控制请求到核验对应 ACK。两模式各 5 轮，每轮 200 次正式操作；计时不含握手或界面刷新。

表3.12 控制请求—ACK RTT 实测

模式	均值/ms	中位数/ms	P95/ms	成功/执行
Suite 1（A）	0.1450	0.1266	0.2552	1,000/1,000
Suite 2（C）	0.1474	0.1300	0.2645	1,000/1,000

采用线性 q(n−1) 分位，失败、超时与迟到保留在分母；本批迟到为 0。时钟校准与测量钩子不作为原语耗时，不做未经测定的扣除。参考目标 P95≤2.0 ms 为文稿整理阶段补充，只对既有数据作回顾性比较。

3.3.2 密码原语适配器（E02—E05）

本轮补测 每组合在 5 个独立进程重复，目标基准时间 2 s，GOMAXPROCS=1。共 19 个组合、95 条基准记录；算法、参数和生产适配器保持不变，随机数和必要检查留在对应计时范围。

表3.13 ML-KEM-768 适配器耗时

过程	中位批均值/ µs	最小批均值/ µs	最大批均值/ µs
ML-KEM-768 KeyGen	53.77	53.05	85.96
ML-KEM-768 Encaps	56.31	55.98	84.79
ML-KEM-768 合法 Decaps	55.15	54.53	77.85

KeyGen 含 RNG、生成、公钥编码、尺寸检查及轻量句柄释放；Encaps 含公钥解析 / 合法性检查和随机数；Decaps 主计时使用合法密文。结构错误和等长隐式拒绝另外验证正确性，err==nil 不等于握手认证成功。

表3.14 SM2 签名与验签适配器耗时

消息/B	签名/ µs	验签/ µs	签名批均值范围/ µs	验签批均值范围/ µs
32	25.65	82.69	25.07—40.07	62.40—95.88
256	33.90	93.23	25.60—36.98	62.77—110.09
1024	38.64	90.14	27.41—40.54	64.76—111.85
4096	49.91	101.03	35.00—58.91	71.77—122.41

签名计时保留随机数、ZA / SM3、ASN.1↔r//s 转换等接口处理；验签保留公钥解析。长期身份密钥生成在计时外。表中中位数均为 5 个批内均值的中位数，最小 / 最大列也是批均值范围。

表3.15 SM4-GCM 适配器微基准（E05 主结果）

明文载荷	Seal（ns/op）	加密（MB/s）	Open（ns/op）	解密（MB/s）
64 B	374.6	170.85	520.5	122.96
256 B	626.4	408.68	604.9	423.21
1,024 B	1,942	527.29	1,723	594.31
4,096 B	6,760	605.92	6,294	650.78

SM4-GCM 使用预分配 dst、33 B AAD、12 B Nonce 与 16 B 标签；本组合 B/op=0。Seal 和 Open 分开测量，换算关系为 **吞吐 MB/s = 1000×明文字节数 / (ns/op)**，1 MB=10^6 B。该吞吐不包含网络、业务及 UI 成本。

另一历史 SM4 批次的 40 条测量作为独立记录保留，本文采用 E05 作为原语主结果，证据导航见 §3.6。

五个独立进程的批均值存在可观察波动。离线复算得到 ML-KEM KeyGen / Encaps / Decaps 的样本变异系数（CV）约为 23.35% / 20.02% / 18.13%，4,096 B SM4-GCM Seal / Open 为 20.23% / 19.68%。CV = 五个批均值的样本标准差 ÷ 其算术平均值；它描述已有重复之间的波动，不是单次调用分布或置信区间。主表中位值用于描述典型批次，不能解释为最坏耗时保证；具体五次值和公式随复算文件保存。

3.3.3 20 设备批量与单进程资源（E06/E07）

本轮补测 E06 从真实工作台记录逐设备提交并等待终态的用户可见批量操作；两模式各 5 轮×10 个正式批次，共 100 批、2,000 个操作均取得关联确认。

表3.16 20 设备 UI 批量操作耗时

模式	均值/s	中位数/s	P95/s	确认批次
Suite 1（A）	19.4580	19.3755	20.0090	50/50
Suite 2（C）	19.4607	19.3856	20.0112	50/50

批量耗时包含逐目标提交、终态等待与 UI 观测，反映本版用户工作流完成时间。单次控制的通信成本由 E01 单列；后续调度优化可进一步比较同步下发与并发终态流程。

表3.17 单进程 OS 生存期峰值工作集（E07）

模式	身份数	重复	峰值组均值/MB	三次峰值范围/MB
Suite 1	1	3	18.74	18.51—18.90
Suite 2	1	3	18.61	18.38—18.94
Suite 1	20	3	23.74	23.64—23.83
Suite 2	20	3	24.12	23.90—24.57

A/C×{1,20 身份}×3 次共 12 次运行，每次 240 s、100 ms 采样，合计 28,800 条。对象是单个 EdgeHybridInteractive.exe 进程，内含 manager、网关与模拟设备 actor，不含浏览器、其他 agent 或整机。PeakWorkingSetSize 是 OS 生存期高水位，与采样最大工作集分列；组均值不是绝对上限。

3.3.4 参考目标与评价口径

表3.18 保留的团队参考目标

指标	参考值	比较范围
ML-KEM KeyGen / Encaps / Decaps	各≤2.0 ms（团队自定参考目标）	E02/E03：对应适配器的批均值统计。
SM2 签名 / 验签	各≤1.5 ms（团队自定参考目标）	E04：所列消息尺寸和真实接口成本。
Suite 2 握手	平均≤5.0 ms（团队自定参考目标）	历史 H 的连续握手均值，不推断单次最坏值。
控制请求—ACK RTT	P95≤2.0 ms（团队自定参考目标）	E01；整理阶段补充，回顾性比较。
SM4-GCM 载荷加解密	各≥20 MB/s（团队自定参考目标）	E05 原语适配器，不是网络 Goodput。
进程运行内存	≤100 MB（团队自定参考目标）	E07 单进程统计；未将三次均值当作硬上界。

参考值不构成赛题规定的门槛，也不代表全部指标的预注册假设。UI 批量耗时和语句覆盖率采用实测描述，不作时延或覆盖率目标达成判断。

3.3.5 从原语成本到用户批量耗时

E05、E01 和 E06 分别回答计算、单次业务确认和用户批量完成三个问题。Suite 2 已建会话的 RTT 不包含再次执行混合握手；E06 的约 19.39 s 包含逐目标等待与界面观测。其耗时远大于原语或单次 ACK RTT，当前证据应支持流程层面的解释，不能把密码内核吞吐直接换算为批量指令性能。

表3.19 三类性能主值及可用结论

计量层次	对应主值	评价用途与限制
原语适配器	E05 Seal：605.92 MB/s（4,096 B）	描述指定载荷下的计算吞吐；不包含网络、握手、业务处理或 UI 等待。
已建通道单次控制	E01 Suite 2：P95 0.2645 ms	描述本机请求至关联 ACK 核验；不代表目标网络时延，也不测混合建钥增量。
20 目标 UI 批量	E06 Suite 2：中位数 19.3856 s	描述实际逐目标终态流程；目前没有据此测得同步下发、并发分位数或密码内核瓶颈。

进一步对照应在相同程序版本、硬件、网络、业务负载和计时口径下，分别比较调度、握手及记录路径。后续验证方案见 §3.6 证据导航，不列为已执行成绩。

3.4 测试数据与结果

机制对照区分传输协议与应用工作台。公开混合 TLS 可将固定长度共享秘密拼接后接入既有密钥调度，并通过转录认证保护协商；SSH 使用交换哈希与签名。TLS 1.2 的记录认证也绑定记录序列号，不仅依赖 TCP 序列号。[16]不能仅凭“拼接”认定缺少认证，也不能从 TLS / SSH 本身推断上层业务没有回执。[17][13][18]

表3.20 密钥建立、认证与应用层次对照

维度	公开 TLS / SSH 机制	本实现 Suite 1	本实现 Suite 2
密钥组合	按具体规范采用传统或混合密钥建立	SM2 共享结果	SM2＋ML-KEM-768
身份认证	依具体协议、证书 / 主机密钥与配置	本实现 SM2 双向身份认证	同左；不是后量子签名认证
上下文	TLS 转录与 SSH 交换哈希接入认证及派生	T2/T4、签名、Finished	共同绑定机制纳入混合分支
记录与业务	协议记录与上层应用分别定义	严格 Seq、遥测验收、控制 ACK	与 Suite 1 共享记录及业务机制
当前对照范围	P 为本项目 TLS 1.3＋X25519MLKEM768 固定配置	T 历史与 A 补测分别标识	H 历史与 C 补测分别标识

历史冻结 P 使用 TLS 1.3＋X25519MLKEM768，双方证书链验证、未启用会话恢复。它是公开混合基线，不是先前取消的自造 B。三者按各自协议栈和身份处理运行，差值不能全部归因于 ML-KEM。

表3.21 历史 T/H/P 握手与用户态字节计数

模式	均值/ms	中位数/ms	P95/ms	成功/执行	发送/返回 B
T	0.9243	1.0001	1.5131	1,000/1,000	308/272
H	1.1129	1.0042	2.0005	1,000/1,000	1492/1360
P	1.2232	1.0079	2.0137	1,000/1,000	2010/2009

字节计数不含 IP/TCP 外层；P 字节数为批内均值后取整显示。历史计时精度限制见 §3.1.3。三组总计 3,000 条，原始 0 ns 观测与失败分母保持。该表仅用于历史实现比较，不能与 E01/E07 拼成同一新运行。

表3.22 历史业务有效吞吐（与 E05 原语吞吐分列）

模式	完成事务	Goodput / B · s^{-1}	确认事务 / s
T	1,000	99612.2	1742.9
H	1,000	114327.9	2000.9
P	1,000	113004.0	1976.5

Goodput 使用各有效轮速率的算术平均，属于既有 M5B 业务工作负载；不是把总字节除以所有批次总时间，更不是 SM4 核函数吞吐。原始各轮内容随 historical_m5_embedded.json 保留。

表3.23 历史进程资源批次均值（每批 100 次握手）

模式	角色	批次	进程 CPU 时间/ms	峰值工作集/MB
T	gateway	5	118.750	15.684
T	device	5	81.250	14.766
H	gateway	5	143.750	15.723
H	device	5	125.000	15.553

表3.23 仅对既有资源文件作离线分组展示：CPU 为从进程启动到最后采样的累计时间，未扣空进程基线，峰值同样属于进程生存期。不得除以握手次数后称为单次密码 CPU 或内存成本。P 未提供同口径资源批次，不补写数值。

EdgeHybrid 面向赛题实现国密与抗量子混合通信及业务确认。历史 T/H/P 对照描述各协议栈的整体成本，进一步部署比较需固定硬件、网络、身份处理与业务负载。

3.5 安全行为、定向功能与质量处置

3.5.1 协商篡改和记录损坏（E09/E10）

表3.24 E09/E10 的输入、终态与分母

验证	输入 / 次数	观察结果	范围
E09 降级矩阵	6 顶层＋9 子测试；含9个降级变体	所测篡改在对应检查处拒绝，不放行业务	包含正常配置与异常输入；非完整安全证明。
E09 TCP 签名篡改	5 次同方式等长修改 ServerHello 签名	客户端身份认证拒绝，无可用 Channel	不是5种攻击，不要求到达 Finished。
E10 Bernoulli误码	24,000 次；4载荷×2域×3种子×1000	变化12,967条全部拒绝；未变化11,033条正常接受	随机比特模型；0断言失败。
E10 Channel损坏	密文 / 标签 / 头部各100次，共300次	拒绝并关闭；无控制处理、无错误确认；后续 Receive 为 Closed	指定域单比特损坏，非同一种 BER 模型。
TCP 正常对照	6 次未修改记录	控制处理与 ACK 正常	从攻击拒绝分母中分开。

记录损坏拒绝证明的是所测输入的安全失败行为，不提供物理信道误码、电磁抗扰或自动重传结论。既有 311 条 TCP 记录按 scope 分组：5 签名＋300 记录损坏＋6 正常，不计成311次降级攻击。

3.5.2 七组定向补测（G01—G07）

本轮补测 7 组各 3 次正式 Go 驱动进程运行，共 21 条命令；日志记录 36 条顶层 PASS 和 27 条子测试 PASS（含重复，对应 12 个不同顶层测试），无 FAIL / SKIP。G06 的子进程 helper 单独记录。

表3.25 七组定向功能验证与适用边界

组别 / 用例	已取得的结果	解释范围
G01 / TC-15	阶段、顺序、删项、设备变更改变元数据根；仅改温度不改根，但改变序列化事件 JSON 哈希	针对测试事件数组；不是篡改真实导出后执行全部导出检查器。
G02 / TC-19	200 / −100℃及0 / 50 / 60001 ms 非法输入拒绝，正常 TCP 对照通过	使用 Suite 1 真实通道验证共有业务校验，不是新建 Suite 2 异常矩阵。
G03 / TC-14	加密ACK截留、释放、迟到确认、旧会话重放，以及错误关联 / 应用失败符合断言	SID / 值错误含函数级负例；late_confirmed 不改成从未执行。
G04 / TC-18	每轮20目标都尝试；D007受控断开不误确认，19健康目标完成；3轮57确认/3拒绝	驱动关闭 Channel 后显式 Disconnect；不是自动检测，也不是UI性能。
G05 / TC-20	3轮阻断5.0005171 / 5.0011729 / 5.0002316 s；显式重连、新SID及后续业务成功	测指定阻断与显式重连，不计自动恢复时限。
G06 / TC-24	每轮两个不同PID；D002吊销保持；D001世代及签名/协商KeyID保持，新SID业务成功	测试宿主非正式GUI EXE；没有逐字节私钥比对或物理断电。

组别 / 用例	已取得的结果	解释范围
G07 / TC-25	3轮各20份换钥回执、40次新SID业务确认；合计60份回执/120次业务确认	公共屏障发起；时间观测不报告严格同步、起跑精度或握手时延。

公开原生日志与快照按运行、设备和操作关联；正常停止事件原样保留。G07 的 start_offset_ns 是相对参考时刻的偏移，不是请求之间的起跑差值。受控换钥功能结论保留，未据其时钟观测报告同步精度。

3.5.3 静态审计、外部对照与发布回归

E08 定点处置 旧扫描记录 go vet 0 诊断、Staticcheck 46 项、gosec 74 项；govulncheck 112 条 finding 涉及17个ID，不能把消息数当漏洞数。分类复核后修补 fleet CLI 负值检查，并处理已定位的标准库依赖风险。

表3.26 E08 处置和新发布验证

项目	原始记录支持的状态	解释范围
代码修补	cmd/fleet/main.go 增加负值检查；481 项源码清单与发布记录对应	有限参数入口修补，不改变混合协议或安全参数。
工具链与程序	8 个既有正式 EXE 的构建记录为 Go 1.27.2	保留新旧构建身份；旧 E01—E07 性能没有重跑。
新依赖扫描	4 finding / 4 ID / 0 函数符号路径	不等于全仓零漏洞；JSON 命令 exit 0 不独立作为通过依据。
定向回归	6 包25项顶层测试通过，0 SKIP / FAIL	限定于所执行路径。
CLI 边界	7项符合预期，含负数预期exit 2	非负输入进入指定配置读取路径，不计为7次联网成功。
正式EXE短流程	D001连接、26.3℃验收、5秒间隔ACK、公开导出及正常停止	与指定EXE哈希关联，不替代所有运行条件。

外部证据复用 Bouncy Castle / OpenSSL 四项独立SM2对照共4个顶层、28个子测试通过。定向 race 共8个顶层、13个子测试通过。旧 core 的206顶层PASS/4SKIP与旧 race 的启动异常原样保留，后续对照与定向运行分别记账，不倒改旧记录。

3.5.4 高精度测量与代码质量保障

完整握手高精度测量使用 Windows QPC，在本机 127.0.0.1 TCP 上调用同生产源码的 Client 与 Server，覆盖临时 SM2 / ML-KEM 交换、身份签名、SM2 确认与密钥派生；长期身份初始化和 TCP 建连在计时外。10 个进程按锁定 T/H 顺序串行执行，两模式各 1000 次正式尝试全部成功，无失败、超时或零耗时样本；双方端点后验和双向业务验证均通过。连续读取计时器的开销另行保存，未从样本扣除。

表3.26a F02 T/H 完整握手 QPC 测量指标（QPC 测试宿主、同生产源码、本机 TCP、身份预加载、未计 TCP 建连/启动、无 race 插桩）

握手套件	样本数（成功/尝试）	均值 (ms)	中位数 (ms)	P95 (ms)	极值区间 (ms)	端点/双向后验
Suite 1 传统 (T)	1,000 / 1,000	0.80	0.75	1.06	0.61 – 1.66	1,000 / 1,000 PASS

握手套件	样本数（成功/尝试）	均值（ms）	中位数（ms）	P95（ms）	极值区间（ms）	端点/双向后验
Suite 2 混合 (H)	1,000 / 1,000	1.15	1.12	1.47	0.88 – 2.46	1,000 / 1,000 PASS

百分位按线性插值 q*(n−1) 计算；每个进程200次，T均值区间 [0.71, 0.93] ms，H均值区间 [1.01, 1.26] ms。本批两模式算术差为 0.3485295 ms，反映完整握手流程差异。历史 M01（1.1129 ms）与各原始样本继续按原环境归档。

并发质量检查采用 WinLibs GCC 15.2.0 与 486 文件增强测试快照，执行 go test -mod=readonly -race -json -p=1 -parallel=2 -timeout=10m ./...，耗时 331.09 s，退出码 0，汇总见表3.26b。

表3.26b F03 全仓可运行测试 Race 回归汇总

包统计	用例总数	通过用例	自然 SKIP 用例	数据竞争（Data Race）
24 包通过 / 5 包无测试	1,137	1,132	5	**0** 项

全仓竞争检测在实际执行的 24 包、1,132 用例中未报告 Data Race。5 个 SKIP 为4项依赖外部工具的 SM2 对照和 TestContinuousTenMinutes。新版普通回归与该历史 race 批次分别记录，普通测试通过数量本身不作为竞争检测结论。

静态质量保障包括语法与依赖检查、规则分析和逐位置安全审查。四类工具针对同一 486 文件快照运行；Staticcheck 和 gosec 经隔离工具兼容性修正后完成有效分析，项目源码和依赖保持该批输入身份。结果及处置分层如下。

- 基础检查：go vet 为0诊断；govulncheck v1.8.0 返回4个模块级条目（GO-2026-5932、GO-2026-6303、GO-2026-6354、GO-2026-6355），0函数符号路径。8个构建目标依赖图显示未引入相应 SSH / OpenPGP 模块，保留调用范围分析。
- Staticcheck 规则分析：纠正重扫取得47条诊断，包括 U1000:19、SA1012:8、ST1005:8、ST1013:6、SA4023:2，以及 S1005、SA2001、SA4006、SA4010各1条。诊断同时涉及未使用代码、参数与控制流等问题，逐位置记录保留。
- gosec 安全审查：有效扫描为74条规则告警，其中 G115:13、G104:6、G124:1、G702:1、G703:1、G103:10、G204:4、G301:5、G302:2、G304:27、G306:4。原分类为24项边界复核、27项条件接受、18项限定范围消解、5项清理或测试维护，按调用条件逐项分析。
- 工具兼容性：首轮 Staticcheck 有6条导入错误；gosec 除52条告警外另有85个文件364条分析错误，其中355条与 export data 格式有关、9条与 strictDecoder 解析有关。纠正重扫后分析错误归零，首轮输出及52项至74项映射随包保留。

扫描结果、工具修正和逐位置登记集中保存在 f04_static/。有效扫描返回的规则告警与工具分析错误分列，便于后续复核和修复。

24项边界复核的进一步审查结果为：3项具备指定受控部署条件下的处置依据，21项仍需补充可达性或访问控制证据；限定范围消解与需修复未实施各0项。该结果适用于对应入口和运行条件，其他50项沿用原分类。后续工程工作优先补齐21项证据，并核对普通入口与受控封装的调用差异。

私钥访问控制审查覆盖 Windows 实际数据根下21个身份、82个 .key 文件和136个路径节点，采用 Get-Acl 读取安全描述符，核查继承关系与可读权限；过程不读取、复制或散列私钥内容。

- 82个私钥路径未列出 Everyone、Authenticated Users、BUILTIN Users 等宽泛主体；该结果描述已枚举的描述符。
- 各路径含继承自 AppData 的未解析本地 SID，其 Allow 0x1200a9 包含 FILE_READ_DATA。账户 / 组查询未解析该主体，跨主体有效访问尚未验证，继续保留“有效访问待核查”状态。

- 当前 Windows 代码未自动配置强隔离 DACL。固定目录和可信运行账户下的封装验证见 §3.5.5；通用部署还需确认主体、目录权限、迁移与恢复流程。

公开材料保留脱敏安全描述符、方法与结论，入口为 f05_acl/。主体解析与有效访问验证是部署审查的重点，现阶段结果如下。

3.5.5 受控目录下的生命周期验证

受控部署先建立应用专属运行、配置与数据目录，再由该批正式程序生成演示身份。前阶段已完成 D001 业务确认，以及 D001、GW001 各一次身份轮换。恢复加载试验从已停止状态经 Restart 启动新实例（PID 9220），同一数据根中的两个身份保持第2代公开身份，42份演示密钥的对象与权限元数据一致。D001 新建会话后，26.5 ℃上报获网关验收，1500 ms间隔设置获设备处理 ACK及confirmed；随后固定 Stop 入口正常退出，信号与应用退出码均为0，HTTP与TCP监听关闭。

试验比较文件对象 / 权限元数据与公开身份字段，包括身份、世代、修订、签名与协商KeyID、生命周期和最低模式。启动前、加载后、业务后、停止后四阶段均保持42个key对象。active.json的file-id随生命周期更新。封装另含21个mock决策用例及33条夹具与多阶段运行时断言，实际生命周期过程按原回执单列。

该试验针对固定目录、指定可信账户和固定入口的部署级控制，历史8个程序字节及其协议实现保持该批身份。管理封装依赖固定 Python 3.12.10 与 Windows PowerShell，其环境要求区别于预编译程序。权限材料包括描述符读回与所列账户的AccessCheck；其他主体有效访问、绕过封装、导入 / 恢复、辅助作业及服务化仍需分别验证，静态审查的未决事项继续保留。

表3.26c 受控部署相关对象的状态区分

对象	本轮准确状态
本轮重启封装故障	已在指定范围修正并补验；v1 原失败与 v2 补验回执并存，原记录不倒改。
新受控部署的创建 / 运行 / 轮换 / 恢复加载 / 停止流程	由前后两份原始回执共同支持，已完成。
其他主体有效访问	未新增验证，保留原范围。
原 74 处 F04 源码告警	保留逐位置与条件映射，不清零。
原 82 项旧密钥对象	未纳入本次措施。
完整提交 ZIP 及最新 PDF 同步	由封包方按实物登记（大小、SHA-256、CRC）。

3.6 证据导航与离线复算入口

以下既有路径及复核命令相对于baseline_v26.zip解压后的EdgeHybrid_Submission_v26。手机材料见verification/phone_v28；新旧身份对应见包根SUBMISSION_IDENTITY.json，原始性能批次不改标。

以下路径和只读命令均相对于程序包根目录；批次回执保留环境、命令与输出。M 对应指标主表，TC / E / G 对应原始证据范围。

表3.27 实验与版本证据导航

对象	包内实际入口	核对要点
发布身份	SUBMISSION_IDENTITY.json；runtime/build_info.json	源码清单、8个EXE、报告路径与SHA-256。
历史握手/资源/Goodput	experiments/historical_m5_embedded.json；experiments/m5_raw_trials/	各自run_id、计划、样本及用户态计数；纯离线复算。
E01 RTT	experiments/supplement_20261008/rtt_summary_01/；rtt_A_*、rtt_C_*	逐次记录、校准、样本分母和分位算法。
E02—E05原语	experiments/supplement_20261008/primitives_formal_01/	19组合×5重复；BENCH_SUMMARY与原stdout。
E06/E07	experiments/supplement_20261008/e06_summary_01/；memory_summary_01/	逐批操作、PID、采样值与OS高水位。
E09/E10	experiments/supplement_20261008/tcp_formal_01/；ber_formal_01/	按scope区分攻击输入、记录损坏和正常对照。
G01—G07	experiments/focused_retest_v11/；verification/focused_v11_review/	原始回传与复核更正并存，不改原日志。
G3/旧SM4	experiments/submission_repair_20261008/	UI换钥和另一SM4 run_id 单独归档。
E08新扫描/回归/短流程	02_evidence/	处置、工具链、构建、定向回归及正式EXE关联。
本版指标与引用	report/METRICS_MASTER_v15.json；report/METRICS_ADDENDUM_v17.json（M13）；report/METRICS_ADDENDUM_v19.json（M14）；report/REFERENCE_MAP_v17.json	主值、原始来源、计算口径与引用映射均随包提供；M14 为同生产源码 QPC 客户端完整握手调用观察区间。
F02 QPC批次	f02_qpc/raw/<run_id>/trials.jsonl、run_meta.json；f02_qpc/implementation/；f02_qpc/QPC_REVIEWED_VERIFICATION.json（当前计数核对）；f02_qpc/QPC_RECEIPT_VERIFICATION.json（原收件记录，保留不倒改）	10进程2000次正式尝试ticks、宿主EXE与源清单身份、计时边界说明及离线复算。
F03 全仓Race	f03_race/stdout.jsonl；f03_race/F03_RACE_SUMMARY.json	24包1132用例通过、0竞争、原始stdout.jsonl与命令回执。
F04 静态复核	f04_static/original_static_01/；f04_static/corrected_static_02/；f04_static/CORRECTED_SCAN_SUMMARY.json	四工具原始日志、纠正重扫原件及逐位置处置；原受阻原件保留。
F04 24项逐项处置	f04_static/disposition/GOSEC_24_FINAL_DISPOSITION_v21.json；GOSEC_24_FINAL_DISPOSITION_v21.md	原24项边界复核记录的逐项终态（3项条件性处置、21项证据不足保留）；原74行表、47条Staticcheck及原分类不变。
F05 私钥ACL	f05_acl/ACL_ORGANIZATION_SUMMARY.md、ACL_INDEPENDENT_REVIEW.json、ACL_SUBJECT_METADATA.sanitized.json	136节点脱敏安全描述符、采集回执及脱敏复核结论；仅脱敏材料，不含原始 Dump。

对象	包内实际入口	核对要点
受控部署补验	controlled_deployment/（脱敏：DELIVERY_RECEIPT.json、FINAL_STOP_VERIFICATION.json、METADATA_BEFORE_RECOVERY/RECOVERY_LOADED/RECOVERY_BUSINESS/FINAL_STOPPED.json、WRAPPER_start/stop/application_exit 记录、LIFECYCLE_MOCK_RESULTS.json、FINAL_DISPOSITION.json、F04_DISPOSITION.json、F05_DISPOSITION.json）	v1 原失败与 v2 补验回执并存、不倒改；before/ 仅历史，control/candidate 当前守卫身份见独立验收；不含私钥、认证材料或 EXE 实体。

证据导航中的归档文件保持各自版本编号。历史批次以 SUBMISSION_IDENTITY.json 、runtime/build_info.json 和 FILE_MANIFEST.sha256 为程序与文件身份入口；新版界面验证位于 verification/ui24/，普通回归与20设备验收位于 verification/current_tests/ 和 verification/live_20/。tools/verify_submission.py 提供只读核对。

```
python tools/verify_release.py --root .
python tools/recompute_trial_v15_metrics.py --check
python tools/verify_final_v17.py --root .
python tools/verify_v21_package.py --root .
```

3.7 手机跨设备功能验证

2026年10月19日，摩托罗拉X30（Android 14，aarch64）经电脑热点连接Windows网关。旧会话为192.168.137.1:9443与192.168.137.106之间的Suite 2连接。本次仅做跨设备功能验证，未测手机握手、局域网RTT、吞吐、功耗和长期稳定性；不直接相减两端时间戳求时延。既有Windows本机性能批次不改标。

表3.28 手机实机功能验证记录

检查项	观测结果	证据与适用范围
独立终端接入	手机完成认证，电脑显示 D001 在线、Suite 2	连接记录与两端相同会话编号；仅验证所述机型与系统
真实温度上报	电脑截图显示 30～31 ℃，原始日志截取包含 95 条被接受的遥测记录	温度来自手机电池，不是环境温度；95 条是保留证据的样本数，不是稳定性时长或精度结论
上报间隔控制	10 秒间隔指令收到手机 ACK，电脑验证并确认；后续继续收到温度	按相同操作编号和会话编号关联，不能仅凭 HTTP 受理判成功
物理执行器提示	1.7.2 兼容更新后，用户现场确认重复设置时均能亮灯并熄灭	实际亮灯由用户观察确认；API 返回记录单独保留，未以调用返回代替物理观测
公开交付复现	完整包在手机独立目录完成新配对接入、持续温度上报及间隔控制，用户确认重复设置均亮灯	新会话使用10443端口，保留42条27 ℃上报及一笔控制确认的网关日志截取；视频尚未录制

联调曾出现震动 API 返回但现场未观察到震动，以及旧闪灯程序只有首次亮灯的问题。保留了相关记录；手机手动执行带预关闭和等待的开关序列可连续亮灯三次，程序采用该时序后用户反馈每次设置均亮灯。该结果支持功能演示，不据此断言手机马达损坏，也不把底层兼容原因写成已查明。

完整包在新手机目录复验。9444端口因Windows保留范围不可绑定，改为已实测可绑定的10443后接入成功。新会话日志截取保留42笔27 ℃上报和匹配控制ACK，后续采集约5秒加API及调度开销；用户确认重复设置均亮灯。相应会话与程序身份保存在验收材料中。

4. 应用前景

4.1 本机业务闭环的三个实例

复现对象是同一 Windows 主机上的网关角色 GW001 与模拟设备 D001。以下步骤是操作说明；一次新运行是否成功，以该次运行保存的原始回执为准。已归档执行证据见 §3.5—3.6。

4.1.1 模拟温度上报与网关验收

1. **建立连接。**双击 runtime\启动交互平台.cmd，访问启动窗口打印的 PAGE_URL 并输入本次一次口令。在工作台选择 D001，打开指引，再点击“连接当前设备”，等待状态显示已认证在线，并核对实际通道模式。程序默认加载设备身份，加载本身不代表已连接。
2. **发送一个确定的样本。**如自动采样已开启，可先在“采样与会话设置”中暂停采样，便于辨认手动样本。在“发送温度”中输入 **26.3 ℃**，点击同名按钮。一次 HTTP 受理仅表示请求进入处理流程。
3. **查看系统检查与结果。**设备将温度和样本标识封装为受 SM4-GCM 保护的业务记录。网关完成记录验密后，重新检查当前可信准入、载荷中的设备身份、温度范围和样本顺序；通过后记录 telemetry_accepted。工作台应显示“网关已收到 26.3 ℃”，并能通过“查看详情与关联记录”定位同一运行、D001、会话和操作对应的记录。

温度 confirmed 来自网关验收，不表示额外遥测 ACK。手动输入不改变自动采样温度源。

4.1.2 设置上报间隔与设备状态 ACK

1. **下发请求。**保持 D001 在线，在“设置间隔”中选择“申请每 5 秒上报一次”，再点击“设置上报间隔”。此时分别保留申请值、已提交值和当前生效值。
2. **核对处理链。**设备验证控制操作标识和允许的间隔范围，完成本地调度器更新，再以实际生效状态生成受安全通道保护的 ACK。网关检查设备、SID、操作标识、Applied 及实际间隔是否与本次请求匹配，匹配后标记确认。
3. **判断成功。**工作台应显示“设备已设置 5 秒上报，网关已验证回执”，当前设备的上报间隔为 5 秒；关联记录中的操作标识与本次提交一致。若此前暂停了采样，间隔更新后仍保持暂停；需要观察周期上报时，再明确开启采样。

操作结果为 unconfirmed 时，设备可能已经执行，不应自动重复下发；会话内去重不等于跨重启严格一次执行。

4.1.3 完整会话换钥与新会话业务

1. **提交明确换钥。**保持四步指引开启，在“采样与会话设置”点击“完整会话换钥”，输入 rekey:D001 确认。记录此次请求对应的 rekey_id 和旧 SID。
2. **核对新握手。**等待指引将此次 rekey_id 关联到设备端完成的新握手和网关端准入，并观测到新旧 SID 不同。只看到请求已受理或 SID 变化时，仍不能把本步骤写成完成。
3. **发送新会话样本。**在换钥确认后手动发送 **28.7 ℃**。指引应显示本次换钥的双端准入已关联，且新 SID 上的验证消息已确认；关联记录必须属于本次运行和 D001。
4. **保存复现材料。**进入“证据总结”，先“锁定当前设备证据范围”，再“导出本次引导证据 JSON”，最后点击生成的下载链接保存文件。导出已生成与文件已保存分别记录。

临时会话更新与长期身份轮换不同。旧 Channel 关闭后重新握手，在新 SID 上继续业务，不恢复旧密钥。

4.2 工业业务映射与适配条件

软件通信机制可作为制造遥测、密码迁移、移动端点和跨域业务的原型基础。工程价值在于标准算法组合、可信配置与可追踪操作，而不是仅凭采用算法便宣称已进入某个工业现场或取得测评认证。

表4.1 已有软件能力与工业适配条件

目标应用	当前可复用的工程基础	后续适配与结论边界
制造设备与能源遥测	温度记录保护、网关验收、间隔控制及实际状态 ACK。	实体 PLC、BMS 与逆变器接入尚需 Modbus、CAN 或其他设备接口适配；未验证急停、运动控制或真实测量精度。历史本机时延和吞吐不能直接作为现场指标。
存量设备密码迁移	可信配置允许的传统模式与混合模式、长期身份维护，以及最低模式升级后关闭不再符合策略的旧会话。	按设备逐步评估和升级；混合失败不自动退回传统模式。现场兼容性、维护窗口和回退流程仍需验证，不承诺零停机、全设备纯软件升级或成本降幅。
门禁与移动车辆通信	设备与网关的认证通信、业务记录保护及完整新握手。	未实现人员或卡片认证、克隆卡检测、V2X 协议、移动切换或碰撞控制。设备身份认证不能代替人员授权，也不构成车辆安全保证。
跨域、关键设施及无线中继	可作为双向安全链路与日志取证的原型基础。	未验证单向隔离设备、核电或水利控制系统、多跳 Mesh、微波链路和现场电磁条件。当前双向握手与回执不能直接套用到物理单向隔离链路；网络丢包、可靠性和测评结论须分别取得证据。

HNDL 提供长期数据保护的迁移动因；实际应用还需要定义接口、失联策略、设备安全状态与运维责任。可复用机制和现场完成情况分开评价，集中范围说明见 §5.2。

4.3 部署成本因素（定性）

当前没有可核实的现场采购、停机、集成及测评成本记录，因此不计算 ROI、回收期或成本降低比例。目标现场应对照相同部署范围与安全约束，分别记录适配、资源、联调、人员培训和运维成本。

表4.2 部署成本因素与目标现场信息

成本因素	当前工程基础	目标现场仍需确认的信息
设备适配	提供传统（Suite 1）与混合（Suite 2）两种模式	既有设备的接口、操作系统、算力与内存是否支持
联调与迁移	提供可信配置约束、身份维护与完整换钥	业务停机窗口、回退流程与现场责任分工
运维	提供应用层回执、审计日志检索与导出	运维频率、人员培训与日志保留策略
正式测评	提供源代码、构建说明与验证记录	具体部署范围、适用要求与独立测评结果

5. 结论

5.1 三项核心成果

A：混合安全握手。完成基于标准原语的 SM2＋ML-KEM-768 四步握手，将可信身份、协商字段、SM2 确认和 Finished 组合为完整过程；用 T2/T4 将确认材料与应用材料分阶段派生。具体结构、状态和材料长度见 §2.1.6—2.1.7。

B：安全记录与业务因果确认。SM4-GCM、方向 Nonce 与严格 Seq 保护所接纳记录；queued→writing→written→confirmed 将通信动作与业务确认区分。温度验收和设备控制 ACK 采用不同证据判据，链式审计摘要明确所覆盖字段与可信根条件。

C：可复现的软件验证与证据体系。按 run_id、源码清单、程序身份和测试编号关联原始记录，分别展示历史性能、补测和复用证据。关键指标主值及批次见当前关键指标主表（表3.11），故障和恢复功能见 G01—G07，质量处置见 E08。本机 Web 工作台、多身份和批量操作是上述机制的工程载体。

本次结果体现从混合建钥、双向认证、记录保护、业务确认到证据导出的软件闭环；测试通过限定在对应输入和观察对象，证据复用与新增运行分别记账。

5.2 已完成能力与工程应用条件

表5.1 已完成能力与工程应用条件

类别	已经完成并可核对	工程应用条件与后续验证
协议	四消息混合握手、T2/T4、国密身份认证、严格记录顺序	完善伙伴会话与组合安全模型，补充完整AKE分析；评估后量子签名认证的协议及配置变更，分析见 §2.1.10。
业务	模拟温度、间隔 ACK、受控换钥与七组定向功能	适配Modbus／OPC UA等实体设备接口，验证自动恢复策略、重复操作与执行器安全状态。
性能	历史 T/H/P；E01—E07；对应批次原始结果	在目标网络、硬件和负载下按相同观察区间复测握手、业务与资源指标，计量方法见 §3.1。
质量	所选 Fuzz／race／外部对照、静态告警处置与定向回归	扩大输入与配置覆盖，推进静态告警处置及目标硬件侧信道评估。
部署	Windows 本机软件、模拟身份、Android ARM64 手机功能验证及配对报告／程序包；应用专属固定目录下的创建→加载→业务→正常停止生命周期补验（见 §3.5.5）	完成工业ARM／MCU与实体工业接口适配，补充其他主体有效访问、导入／恢复和服务化验证；结合目标环境开展EMC／DPA／CPA测评，工程范围见 §2.1.1。

当前成果形成 Windows 本机软件原型、模拟设备业务流程、Android ARM64 实机功能验证与可复算实验材料。目标现场的接口、运维、账户权限和设备安全状态需共同定义，表5.1列出了应用前的验证重点。

竞赛交付包括配对的软件、设计报告、原始实验与验证脚本。工程应用阶段应优先完成静态审查未决事项和私钥有效访问验证，再结合现场设备、账户权限与运维流程开展独立测评。

5.3 后续方向与结束语

后续工作由实际部署与研究需求启动：优先对四消息及身份 / 会话匹配建立形式化模型，在手机功能验证基础上补充 ARM64 资源与性能统计，随后完成实体工业接口适配，并按目标硬件开展侧信道和环境测评。工具方法可参考已有 ProVerif 与 TLS 符号分析研究，但必须建立模型与本实现的对应关系。[19] [20]

后续研究以协议形式化分析为主线，工程工作以静态问题闭合、目标硬件验证和真实接口适配为重点。源代码、原始日志与复算入口为这些工作提供可追踪的基础，相关开放与合作遵循权利和许可证约定。

附录 A 术语与缩略语

术语定义用于本文阅读，不代表本作品已经证明所列全部安全属性。密码参数、原语安全与协议安全分层理解。

表A.1 主要术语、定义与使用范围

缩略语	英文全称	中文规范译名	专业定义与在本项目中的应用
PQC	Post-Quantum Cryptography	后量子密码 / 抗量子密码	能够抵抗经典计算机和大规模量子计算机破解的公钥密码算法体系。
ML-KEM	Module-Lattice-Based Key Encapsulation Mechanism	基于模格的密钥封装机制	NIST FIPS 203 标准化的抗量子密钥封装机制（原 CRYSTALS-Kyber），本项目 Suite 2 核心。
SM2	SM2 Elliptic Curve Cryptography	SM2 椭圆曲线公钥密码算法	中国商用密码标准（GB/T 32918），基于 256 位素数域椭圆曲线，用于数字签名与密钥交换。
SM3	SM3 Cryptographic Hash Algorithm	SM3 密码杂凑算法	中国商用密码标准（GB/T 32905），输出 256 位哈希值，用于 KDF 派生与握手转录摘要。
SM4-GCM	SM4 in Galois/Counter Mode	SM4 伽罗瓦计数器认证加密模式	使用 SM4 作为分组密码的 GCM 认证加密，保护明文并认证关联数据；要求同密钥 Nonce 不重复。
HNDL	Harvest-Now-Decrypt-Later	先存储后解密攻击 / 延迟解密	敌对势力预先嗅探存储敏感密文，待实用量子计算机问世后再行破解的战略威胁。
LWE	Learning With Errors	容错学习问题	给定模线性关系及其小误差的学习问题；求解 / 判定版本、误差分布和参数应明确定义。相关归约不等于对任意具体参数给出无条件安全证明。
MLWE	Module Learning With Errors	模容错学习问题	定义在多项式环上的模向量 LWE 变体；ML-KEM 的安全依据涉及这一问题及所选参数、变换和实现条件。
NTT	Number Theoretic Transform	数论变换	在有限域上高效计算多项式乘法的算法，将多项式乘法复杂度从 O(n^2) 降至 O(n log n)。
KDF	Key Derivation Function	密钥派生函数	从共享秘密与上下文信息中确定性派生出一个或多个伪随机密钥的安全密码原语。
AEAD	Authenticated Encryption with Associated Data	带关联数据的认证加密	在提供数据机密性加密的同时，提供真实性与完整性校验标签的对称密码工作模式。
GMAC	Galois Message Authentication Code	伽罗瓦消息认证码	GCM 在仅认证情形下的消息认证机制；标签包括 GHASH 与分组密码生成的掩码，不等于单独 GHASH。
Nonce	Number used once	一次性随机数 / 独占计数值	同一方向流量密钥作用域内不得重复的输入。本实现使用 KDF 前缀加 64 位序号；不要求每次随机采样。
Transcript Hash	Transcript Hash	转录哈希摘要	对域分隔、编码后的握手消息计算的阶段摘要。本实现区分 T2 和 T4；摘要需与认证和派生结合。
WAL	Write-Ahead Logging	预写日志	在将状态变更刷入主数据库前，预先将事务记录持久化于追加日志以保障原子性与掉电安全。
SCADA	Supervisory Control and Data Acquisition	数据采集与监视控制系统	用于工业生产过程调度控制、参数采集监测的大型分布式自动化控制软件体系。
DCS	Distributed Control System	分散控制系统 / 分布式控制系统	采用多级分层、分散控制、集中监视的工业过程连续控制中枢系统。
PLC	Programmable Logic Controller	可编程逻辑控制器	面向工业现场的数字运算操作电子系统，执行逻辑控制、顺序控制与运动调速。
RTU	Remote Terminal Unit	远程测控终端	部署在野外或变电站等远端现场，负责远距离遥测、遥信采集与遥控执行的嵌入式微设备。

缩略语	英文全称	中文规范译名	专业定义与在本项目中的应用
Modbus TCP	Modbus over TCP/IP	Modbus 工业以太网通信协议	工业自动化领域最广泛使用的通用主从通信协议，默认在 TCP 502 端口以明文交互。
OPC UA	OPC Unified Architecture	OPC 统一架构	跨平台、面向服务的工业互联互通标准规范，支持复杂数据模型与安全策略协商。
CAN	Controller Area Network	控制器局域网总线	用于汽车电子与严苛工业现场的多主串行总线通信标准，抗干扰性强但缺乏原生加密。
RS-485	Recommended Standard 485	RS-485 差分平衡串行通信规范	工业物理层电气规范，支持多点、远距离（达1200米）差分信号传输。
ProVerif	Automated Cryptographic Protocol Verifier	自动化密码协议形式化验证工具	基于应用 pi 演算建模、使用重写规则证明认证性与机密性的形式化验证求解器。
DPA	Differential Power Analysis	差分功耗分析攻击	通过统计分析密码硬件在执行运算时的物理功耗微小差异恢复密钥的侧信道攻击手段。
CPA	Correlation Power Analysis	相关功耗分析攻击	利用功耗模型（如汉明重量）与实测能量迹之间的皮尔逊相关系数恢复私钥的侧信道方法。
Timing Attack	Timing Side-Channel Attack	时序侧信道攻击	通过测量密码算法在处理不同输入时耗时的细微差异来推导私钥信息的非侵入式攻击。
Constant-Time	Constant-Time Execution	常数时间执行	使控制流与内存访问等不依赖敏感输入的实现要求；具体保障受实现、平台和威胁模型约束，不能等同于消除一切物理侧信道。
Rekeying	Dynamic Session Rekeying	动态会话换钥机制	在加密通信持续达到一定时限或报文计数阈值时，自动重新协商或派生新密钥。
BKZ	Block Korkine-Zolotarev Algorithm	BKZ 格基约简算法	块格基约简算法，可结合具体成本模型用于格攻击评估；估计成本不是严格攻击下界。
Sieve	Lattice Sieve Algorithm	格筛法算法	利用向量组合筛选寻找短格向量的一类算法；复杂度依维数、内存与计算模型而定。
SVP	Shortest Vector Problem	最短向量难题	给定格，寻找欧几里得范数最小的非零格向量；复杂性结论需明确精确 / 近似版本及归约条件。
CVP	Closest Vector Problem	最近向量难题	给定格与目标点，寻找距离目标点最近的格向量；本报告不声称一般 CVP 与 LWE 等价。
GM/T	Guomi Standards Series	国家密码行业标准规范代号	国家密码管理局颁布的商用密码行业标准，如 GM/T 0003 (SM2)、GM/T 0004 (SM3)。
GB/T 39786	GB/T 39786-2021 Standard	信息安全技术 信息系统密码应用基本要求	我国商用密码应用安全性评估（密评）的核心基准国家标准。
FIPS 203	Federal Information Processing Standard 203	美国联邦信息处理标准第203号	NIST 于 2024 年 8 月正式颁布的基于模格的密钥封装标准（ML-KEM 官方规范）。
IND-CCA2	Indistinguishability under Adaptive CCA	适应性选择密文攻击下的不可区分性	在约定挑战限制下，允许自适应解密 / 解封装查询时的不可区分性定义；不是涵盖所有安全属性的最高等级。
EUF-CMA	Existential Unforgeability under CMA	选择消息攻击下的存在性不可伪造	攻击者可请求所选消息的签名，但不能为未请求的新消息生成有效签名的安全定义；与强不可伪造等性质须分别区分。
PFS	Perfect Forward Secrecy	完全前向安全性	长期身份秘密在会话结束后泄露时，历史会话密钥在模型规定的新鲜性与秘密清理条件下仍保持保密的目标；不由名称直接宣称本协议已证明。
Ledger Root	Cryptographic Hash Ledger Root	密码学单向链式审计摘要根	对运行标识及选定事件元数据逐项计算的链式摘要；字段覆盖范围见§2.1.9，不能代表全部交易载荷不可篡改。

附录 B　正文引用与参考文献

本表仅保留正文或技术附录实际引用的资料。原语规范、公开协议和研究方法支撑各自机制说明；本项目数值结论由第3章列明的原始实验文件支撑。参考文献不替代项目安全证明或认证。

1. Shor P W. Algorithms for quantum computation: discrete logarithms and factoring[C]// Proceedings of the 35th Annual Symposium on Foundations of Computer Science. IEEE, 1994: 124–134.
2. Mosca M. Cybersecurity in an Era with Quantum Computers: Will We Be Ready?[J]. IEEE Security & Privacy, 2018, 16(5): 38–41.
3. National Institute of Standards and Technology (NIST). FIPS PUB 203: Module-Lattice-Based Key-Encapsulation Mechanism Standard[S]. Gaithersburg: U.S. Department of Commerce, 2024.
4. GB/T 32918 系列. 信息安全技术 SM2 椭圆曲线公钥密码算法[S]. 本文涉及第2部分（数字签名）与第3部分（密钥交换），2016.
5. GB/T 32905-2016. 信息安全技术 SM3 密码杂凑算法[S]. 2016.
6. GB/T 32907-2016. 信息安全技术 SM4 分组密码算法[S]. 2016.
7. Yang P. ShangMi (SM) Cipher Suites for TLS 1.3: RFC 8998[R]. RFC Editor, 2021. DOI:10.17487/RFC8998.
8. Lyubashevsky V, Peikert C, Regev O. On Ideal Lattices and Learning with Errors over Rings[J]. Journal of the ACM (JACM), 2013, 60(6): 43:1-43:35. DOI:10.1145/2535925.
9. Bos J, Ducas L, Kiltz E, et al. CRYSTALS-Kyber: A CCA-secure module-lattice-based KEM[C]// 2018 IEEE European Symposium on Security and Privacy (EuroS&P). London, UK: IEEE, 2018: 353-367.
10. Krawczyk H, Eronen P. HMAC-based Extract-and-Expand Key Derivation Function (HKDF): RFC 5869[R]. RFC Editor, 2010. DOI:10.17487/RFC5869.
11. National Institute of Standards and Technology (NIST). NIST SP 800-38D: Recommendation for Block Cipher Modes of Operation: Galois/Counter Mode (GCM) and GMAC[S]. 2007.
12. Alagic G, Barker E, Chen L, et al. Recommendations for Key-Encapsulation Mechanisms: NIST SP 800-227[S]. NIST, 2025. DOI:10.6028/NIST.SP.800-227.
13. Stebila D, Fluhrer S, Gueron S. Hybrid Key Exchange in TLS 1.3: RFC 9954[R]. IETF, 2026. DOI:10.17487/RFC9954.
14. Ueno R, Xagawa K, Tanaka Y, Ito A, Takahashi J, Homma N. Curse of Re-encryption: A Generic Power/EM Analysis on Post-Quantum KEMs[J]. IACR Transactions on Cryptographic Hardware and Embedded Systems, 2022(1): 296-322. DOI:10.46586/tches.v2022.i1.296-322.
15. Go Authors. Go 1.27.1 Windows/amd64 时钟实现[EB/OL]. [2026-10-19]. https://github.com/golang/go/blob/go1.27.1/src/runtime/time_windows_amd64.s；https://github.com/golang/go/blob/go1.27.1/src/runtime/sys_windows_amd64.s.
16. Dierks T, Rescorla E. The Transport Layer Security (TLS) Protocol Version 1.2: RFC 5246[S]. IETF, 2008. DOI:10.17487/RFC5246.
17. Rescorla E. The Transport Layer Security (TLS) Protocol Version 1.3: RFC 8446[S]. Internet Engineering Task Force (IETF), 2018.
18. Ylonen T, Lonvick C. The Secure Shell (SSH) Transport Layer Protocol: RFC 4253[S]. IETF, 2006. DOI:10.17487/RFC4253.
19. Blanchet B. Modeling and Verifying Security Protocols with the Applied Pi Calculus and ProVerif[J]. Foundations and Trends in Privacy and Security, 2016, 1(1-2): 1-135.
20. Cremers C, Horvat M, Hoyland J, Scott S, van der Merwe T. A Comprehensive Symbolic Analysis of TLS 1.3[C]// Proceedings of the 2017 ACM SIGSAC Conference on Computer and Communications Security (CCS '17). Dallas, TX: ACM, 2017: 1773-1788. DOI:10.1145/3133956.3134063.

附录 C　标准算法说明与线格式解析片段

C.1 SM2 签名与 SM3 压缩流程

以下为按相应标准整理的说明伪代码，并非本项目密码源码。SM2 完整参数与检查、SM3 填充、初值、轮常量及函数定义按标准；省略内容不能作为独立可运行实现。[4][5]

算法C.1　SM2 数字签名与验证说明

```
Algorithm SM2.Sign(dA, M, IDA):
 1: ZA = SM3(ENTLA || IDA || a || b || xG || yG || xA || yA)
 2: M_bar = ZA || M;  e = SM3(M_bar)
 3: Loop:
 4:     k ← [1, n-1]; (x1, y1) = [k]G
 5:     r = (e + x1) mod n; If r == 0 or r + k == n Then Continue
 6:     s = ((1 + dA)^(-1) * (k - r * dA)) mod n; If s == 0 Then Continue
 7:     Return (r, s)

Algorithm SM2.Verify(PA, M, IDA, (r, s)):
 1: If r, s not in [1, n-1] Then Return FAIL
 2: ZA = SM3(ENTLA || IDA || a || b || xG || yG || xA || yA)
 3: e = SM3(ZA || M);  t = (r + s) mod n;  If t == 0 Then Return FAIL
 4: (x1', y1') = [s]G + [t]PA;  R = (e + x1') mod n
 5: If R == r Then Return SUCCESS Else Return FAIL
```

算法C.2　SM3 的64轮压缩说明

```
Algorithm SM3.Compress(V_i, B_i):
 1: 消息字扩展: 对 512 位分组 B_i 划分为 16 个字 W_0~W_15
 2: For j = 16 to 67: W_j = P1(W_{j-16} ^ W_{j-9} ^ (W_{j-3} <<< 15)) ^ (W_{j-13} <<< 7) ^ W_{j-6}
 3: For j = 0 to 63: W'_j = W_j ^ W_{j+4}
 4: (A, B, C, D, E, F, G, H) = V_i
 5: For j = 0 to 63:
 6:     SS1 = ((A <<< 12) + E + (T_j <<< (j mod 32))) <<< 7
 7:     SS2 = SS1 ^ (A <<< 12)
 8:     TT1 = FF_j(A, B, C) + D + SS2 + W'_j
 9:     TT2 = GG_j(E, F, G) + H + SS1 + W_j
10:    D = C; C = B <<< 9; B = A; A = TT1
11:    H = G; G = F <<< 19; F = E; E = P0(TT2)
12: Return V_i ^ (A, B, C, D, E, F, G, H)
```

C.2 完整单帧字段解析示意

以下 Lua 片段读取完整单帧的外层长度和受保护记录头；不构成已验证的 TCP 分段重组插件。端口由运行配置指定，片段只用于线格式理解，与表1.5对应。

```
-- EdgeHybrid Protocol Dissector for Wireshark (按冻结线格式)
-- 外层 wire 帧: uint32(BE) 剩余长度 | uint8 版本(=1) | uint8 kind | payload
-- 内层受保护记录头(33B): ver(1) | suite(2) | kind(1) | dir(1) | sid(16) | epoch(4) | seq(8)
local eh_proto = Proto("EdgeHybrid", "EdgeHybrid Post-Quantum Security Protocol")

local f_len   = ProtoField.uint32("eh.len",   "Frame Remaining Length", base.DEC)
local f_ver   = ProtoField.uint8 ("eh.ver",   "Frame Version", base.DEC)
local f_kind  = ProtoField.uint8 ("eh.kind",  "Message Kind", base.HEX)
local f_suite = ProtoField.uint16("eh.suite", "Cipher Suite", base.DEC)
local f_dir   = ProtoField.uint8 ("eh.dir",   "Direction", base.DEC)
local f_sid   = ProtoField.bytes ("eh.sid",   "Session ID")
local f_epoch = ProtoField.uint32("eh.epoch", "Epoch", base.DEC)
local f_seq   = ProtoField.uint64("eh.seq",   "Sequence (nonce low 64)", base.DEC)

eh_proto.fields = { f_len, f_ver, f_kind, f_suite, f_dir, f_sid, f_epoch, f_seq }

function eh_proto.dissector(buffer, pinfo, tree)
   if buffer:len() < 6 then return end
   local rem = buffer(0,4):uint()
   if rem ~= buffer:len() - 4 then return end          -- 长度自洽才认为是本协议
   pinfo.cols.protocol = "EdgeHybrid"
   local st = tree:add(eh_proto, buffer(), "EdgeHybrid Frame")
   st:add(f_len,  buffer(0,4))
   st:add(f_ver,  buffer(4,1))
   local kind = buffer(5,1):uint()
   st:add(f_kind, buffer(5,1))
   if kind == 16 and buffer:len() >= 6 + 33 then         -- ProtectedRecord
      local off = 6
      st:add(f_suite, buffer(off+1,2))
      st:add(f_dir,   buffer(off+4,1))
      st:add(f_sid,   buffer(off+5,16))
      st:add(f_epoch, buffer(off+21,4))
      st:add(f_seq,   buffer(off+25,8))
   end
end

-- 记录层运行在 TCP 上；端口由运行配置决定（控制台仅监听 127.0.0.1 本机端口），
-- 因此这里按“解析器”注册，由上层按实际端口绑定，不写死某个公开端口。
```

附录 D 关键机制失效与故障注入验证

围绕混合分支依赖、最终转录绑定与严格记录序号，采用定向变异测试检查既有用例能否发现关键机制退化。试验通过 Go -overlay 在隔离进程中替换指定实现，依次运行正常基线、单项失效与恢复检查，生产源码文件和历史样本保持原身份。

D.1 实验设计与判据

P01—P04每次仅改变一个机制，目标测试须实际执行并产生预期断言失败才计为检出；编译失败、工具错误与超时另行记录。工具链为Go 1.27.2 windows/amd64，禁用工具链切换与模块联网下载。

表D.1 四项定向机制失效结果

编号	隔离失效	对应不变量	注入结果	基线 / 恢复
P01	SM2共享值替换为等长零值	改变SM2分支应改变派生结果	目标断言FAIL	均PASS
P02	PQ共享值替换为等长零值	改变PQ分支应改变派生结果	目标断言FAIL	均PASS
P03	应用材料展开用零值代替T4	最终转录变化应改变应用材料	目标断言FAIL	均PASS
P04	禁用接收序号相等检查	真实SM4-GCM记录拒绝乱序 / 重放	目标断言FAIL	均PASS

四项指定失效均被检出（4/4），目标断言失败进程均退出1；两包正常基线及两包恢复检查均退出0。原试验前后核对487个源码树文件，内容身份一致。结果表明所选用例能够识别这四种机制回归，评价范围限于对应替换与断言。

D.2 贡献对应与复现

P01—P03对应internal/handshake/keyschedule.go中的两分支输入和T4应用材料绑定；P04对应记录层严格序号不变量。控制ACK、完整换钥及其他安全机制由相应定向用例提供独立记录。本组实验用于检验测试对指定退化的敏感性。

```
python -X utf8 -B tools/run_mechanism_probe.py --out "%TEMP%\EdgeHybridProbeNew"
```

以上为CMD示例；PowerShell使用$env:TEMP。输出选择包外尚不存在的新目录，运行需要Go和依赖缓存。原始日志、覆盖文件与逐条回执位于verification/mechanism_20261018/；重放记录位于verification/mechanism_20261019/。

```
python -X utf8 -B tools/verify_submission.py
```

只读核对入口验证文件清单、当前构建、12个历史主指标和保存的实验记录。新界面构建的普通回归与业务验收独立保存，历史性能结果保持其采样程序身份。